



Instituto Superior de
Engenharia do Porto

TRAFFIC ANALYSIS

TRABALHO PRÁTICO 1

SEGS - SEGURANÇA DE SISTEMAS E INFORMAÇÃO



TRABALHO DESENVOLVIDO POR:

PEDRO COELHO - 1240485

PEDRO FERREIRA - 1201172

PEDRO MOREIRA - 1211138

Índice

Introdução.....	5
Intervenientes	5
Protocolo Principal	5
Operações realizadas pelo protocolo principal	6
Problemas de Segurança e Mitigações	6
Análise das Capturas	7
Captura 1 – CAP1.pcapng – Pedro Coelho - 1240485.....	7
Intervenientes	7
Protocolo Principal	7
Operações realizadas pelo protocolo principal.....	7
Problemas de Segurança	9
Mitigações.....	9
Outras Considerações.....	9
Captura 2 – CAP2.cap – Pedro Coelho - 1240485	10
Intervenientes	10
Protocolo Principal	10
Operações realizadas pelo protocolo principal.....	11
Problemas de Segurança	12
Mitigações.....	13
Outras Considerações.....	13
Captura 3 – CAP3.cap – Pedro Ferreira - 1201172	13
Intervenientes	13
Protocolo Principal	14
Operações realizadas pelo protocolo principal.....	14
Problemas de Segurança	16
Mitigações.....	17
Outras Considerações.....	17
Captura 4 – CAP4.cap – Pedro Ferreira - 1201172.....	17
Intervenientes	17
Protocolo Principal	17
Operações realizadas pelo protocolo principal.....	18
Problemas de Segurança	18
Mitigações.....	19
Outras Considerações.....	19

Captura 5 – CAP5.pcap – Pedro Moreira – 1211138	19
Intervenientes	19
Protocolo Principal	20
Operações realizadas pelo protocolo principal.....	21
Problemas de Segurança	23
Mitigações	24
Outras Observações	25
Captura 6 – CAP6.pcap – Pedro Moreira – 1211138	26
Intervenientes	26
Protocolo Principal	26
Operações realizadas pelo protocolo principal.....	27
Problemas de Segurança	27
Mitigações	28
Outras Observações	28
Conclusão	29
Referências	29
Análise Exercícios PLs	30
PLo1 - Exercício 2	30
Describe the Radius protocol that you see (What it does, what purpose it serves and its security considerations).	30
Describe the Challenge Authentication Principle?	30
Crack the credential using any password cracker such as JohnTheRipper or Hashcat.	30
While it is cracking comment on the resilience of the cipher.	31
PLo3 - Exercício 3.....	32
Deploy BadBlood on your testing domain.....	32
Download and run Bloodhound	33
Install Neo4J Desktop [5] and load your results into the Database using the BloodHound binaries.....	34
Try to trace a potential attack vector and how could you exploit it using the Hacktricks Database	36

Índice de Imagens

Figura 1 - Intervenientes e Protocolo Principal.....	7
Figura 2 - LDAP bind e search Request	7
Figura 3 - Three-way Handshake	7
Figura 4 – Autenticação.....	7
Figura 5 - Consulta de Informação	8
Figura 6 - Pedido 12.....	8
Figura 7 - Transferência de Dados.....	8
Figura 8 - Exposição da password em texto claro no pacote de autenticação	9
Figura 9 - INTERVENIENTES CAP 2	10
Figura 10 - SERVIÇO DE EMAILS DO SERVIDOR	10
Figura 11 - Email identificador do Cliente/Utilizador	10
Figura 12 - Captura do Follow TCP Stream	12
Figura 13estatísticas ipv4 na captura 3.....	13
Figura 14Exemplo de comunicação protocolo ftp & tcp - imagem 1	13
Figura 15exemplo de comunicação protocolo ftp & tcp - imagem 2	14
Figura 16estatísticas da hierarquia de protocolo da captura 3.....	14
Figura 17estabelecimento da comunicação entre cliente e servidor.....	14
Figura 18Mensagem de confirmação do servidor de acessibilidade dos serviços para o cliente	15
Figura 19autenticação do cliente no servidor através do FTP.....	15
Figura 20Visibilidade de dados sensíveis no processo de autenticação do cliente no servidor.....	15
Figura 21Exemplo de comando LIST através do FTP.....	15
Figura 22exemplo do comando retr através do ftp	16
Figura 23exemplo do comando xpwd através do ftp.....	16
Figura 24exemplo do comando nlst através do ftp	16
Figura 25resposta de listagem do servidor ao comando nlst.....	16
Figura 26 - Protocolo Radius.....	19
Figura 27- Cliente pfSense.home.arpa.....	19
Figura 28 - Servidor Radius.....	19
Figura 29- Utilizador Autenticado "BOB".....	20
Figura 30 - Attribute vendor-specific provider MS CHAP/MPPE.....	20
Figura 31 - Protocolo	21
Figura 32 - Tipo de pedido: ID.....	21
Figura 33 - Autenticador	21
Figura 34 - Tipo de pedido: Login.....	21
Figura 35 - Autenticador e tempo de resposta (segundos)	22
Figura 36 - MS-CHAP-MPPE-Keys, MS-MPPE-Encryption-Policy e MS-MPPE-Encryption-Types	22
Figura 37 - MS-CHAP challenge - response	23
Figura 38 - Origem e Destino ping DCERPC.....	26
Figura 39 - Protocolo de autenticação Kerberos	27
Figura 40 - kerberos 5.....	27
Figura 41 - ping.....	27
Figura 42 - Fingerprinting padrão UUID.....	28
Figura 43 - Username da identidade a ser atacada.....	30
Figura 44 - Valor do Challenge.....	31

Figura 45 - Valor do Request.....	31
Figura 46 - Informação de Sucesso	31
Figura 47 - Password em texto.....	31
Figura 48 - Comandos para instalar BadBlood	32
Figura 49 - Resultado de correr os comandos	32
Figura 50 - Resultados de Correr comandos 2	32
Figura 51 - Comandos para instalar BloodHound	33
Figura 52 - Comandos para contornar Windows Defender.....	33
Figura 53 - Comandos para correr BloodHound	33
Figura 54 - Ficheiro do resultado de correr o BloodHound	34
Figura 55 - Ficheiro do Resultado de correr o BloodHound fora da VM	34
Figura 56 - Base de Dados no Neo4J	34
Figura 57 – Conexão do BloodHound à BD.....	35
Figura 58 - Conexão bem sucedida	35
Figura 59 - Upload dos dados do BloodHound	36
Figura 60 - Domain Admins	36
Figura 61 - Vetor de Ataque.....	37

Introdução

A análise de tráfego de rede é uma competência fundamental no campo da segurança da informação, permitindo a identificação de protocolos inseguros, a detecção de anomalias e a auditoria de comunicações. O presente relatório é desenvolvido no âmbito da unidade curricular de Segurança de Sistemas e de Informação (SESGI) e corresponde à análise detalhada de um conjunto de capturas de pacotes, conforme proposto no primeiro trabalho prático.

As análises serão realizadas através da ferramenta Wireshark, onde cada captura foi examinada com o objetivo de identificar os intervenientes, o protocolo principal em uso e o fluxo das operações realizadas. Com um foco particular em analisar o tráfego de redes para obter insights baseados em padrões de tráfego de rede que possam ajudar equipas não só a encontrar vulnerabilidades, mas principalmente a mitigá-los.

Para este primeiro trabalho prático o objetivo era, que cada aluno do grupo, analisasse o tráfego encontrado em determinadas capturas. Para isso, foi nos fornecido um conjunto de capturas de pacotes feitas, e cada aluno teria de analisar duas dessas capturas

A estrutura deste relatório vai começar com uma secção de enquadramento, onde vão ser detalhados os critérios de análise aplicados a cada captura.

No final serão também apresentados os exercícios das aulas PLs que foram atribuídos ao grupo para realizar.

Intervenientes

Compreender um fluxo de tráfego de rede começa por identificar os seus intervenientes. Estes são os pontos finais da comunicação, ou seja, as entidades que originam e recebem o diálogo na rede.

Fundamentalmente, cada interveniente é representado por um endereço único que o localiza na rede. No âmbito das redes TCP/IP, este endereço é o endereço IP. Portanto, a análise dos endereços IP de origem (quem envia) e de destino (quem recebe) é o passo essencial para mapear a comunicação e determinar o papel de cada participante.

Protocolo Principal

Se os intervenientes são os participantes da comunicação, o protocolo principal é de certa forma o idioma e o conjunto de regras que eles usam para atingir um objetivo específico. Numa captura de tráfego, múltiplos protocolos atuam em conjunto, mas o "principal" é aquele da camada de aplicação que define a finalidade da troca de dados. Os principais exemplos são **POP3, LDAP, HTTP, entre vários outros**.

A identificação deste protocolo é, portanto, essencial para a análise de segurança, pois é na sua sintaxe e nas suas operações que a informação sensível, como credenciais e dados privados, é transportada. É neste nível que se avalia inicialmente se a comunicação é ou não segura.

Operações realizadas pelo protocolo principal

Após definição de quem está a comunicar e quais são as regras e o “idioma” com o qual comunicam, a análise foca-se nas **operações realizadas**, que descrevem o fluxo e a sequência da comunicação. Esta etapa consiste em interpretar o “diálogo” entre os intervenientes, passo a passo.

Compreender esta sequência é crucial para determinar a natureza da atividade (se é uma autenticação, uma transferência de ficheiros ou uma consulta) e para contextualizar os problemas de segurança.

Problemas de Segurança e Mitigações

Nesta secção, após análise da captura vamos tentar identificar os principais problemas relativamente à segurança do tráfego. Esta identificação foca-se em detetar quaisquer fraquezas, configurações incorretas ou características de um protocolo que possam ser exploradas por qualquer pessoa que tenha acesso à capture específica, comprometendo a confidencialidade, integridade e disponibilidade da informação.

O principal objetivo após identificar o/os problema/as será propor uma forma de mitigar esta fraqueza. A mitigação pode consistir numa ação, configuração ou alterar a tecnologia ou protocolo, de forma a eliminar ou no pior dos casos minimizar o risco associado a essa vulnerabilidade.

Análise das Capturas

Captura 1 – CAP1.pcapng – Pedro Coelho - 1240485

Intervenientes

- **Cliente:** A máquina com o endereço IP 192.168.178.130. É esta entidade que inicia a comunicação, como se pode verificar pelo primeiro pacote SYN da captura.
- **Servidor:** A máquina com o endereço IP 192.168.178.132, que recebe a ligação na porta 389 e responde aos pedidos do cliente.
- **Utilizador:** A comunicação é autenticada em nome do utilizador CN=Bob B. Munchies,CN=Users,DC=segsi_domain, DC=local

1	0.000000	192.168.178.130	192.168.178.132	TCP	66 50442 → 389 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2	0.000494	192.168.178.132	192.168.178.130	TCP	66 389 → 50442 [ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
3	0.000750	192.168.178.130	192.168.178.132	TCP	54 50442 → 389 [ACK] Seq=1 Ack=1 Win=2102272 Len=0
4	0.017491	192.168.178.130	192.168.178.132	LDAP	130 bindRequest(1) "CN=Bob B. Munchies,CN=Users,DC=segsi_domain,DC=local" simple
5	0.019608	192.168.178.132	192.168.178.130	LDAP	76 bindResponse(1) success
6	0.020861	192.168.178.130	192.168.178.132	TCP	54 50442 → 389 [FIN, ACK] Seq=77 Ack=23 Win=2102272 Len=0
7	0.021956	192.168.178.132	192.168.178.130	TCP	66 389 → 50442 [ACK] Seq=23 Ack=78 Win=2102272 Len=0
8	0.022203	192.168.178.132	192.168.178.130	TCP	66 389 → 50442 [RST] Seq=23 Ack=78 Win=0 Len=0

FIGURA 1 - INTERVENIENTES E PROTOCOLO PRINCIPAL

Protocolo Principal

- O protocolo de aplicação dominante e que define o propósito desta comunicação é o **LDAP** (Lightweight Directory Access Protocol), que opera sobre **TCP**. Este protocolo é que define as regras para a comunicação entre os intervenientes
- Essas regras podem ser vistas durante o resto da comunicação, por exemplo através dos comandos **bindRequest** (para autenticação) e **searchRequest** (para pesquisar).

4	0.017491	192.168.178.130	192.168.178.132	LDAP	130 bindRequest(1) "CN=Bob B. Munchies,CN=Users,DC=segsi_domain,DC=local" simple
5	0.019608	192.168.178.132	192.168.178.130	LDAP	76 bindResponse(1) success

FIGURA 2 - LDAP BIND E SEARCH REQUEST

Operações realizadas pelo protocolo principal

As operações podem ser divididas em 3 principais fases:

- **Estabelecimento da ligação (Pacotes 1 a 3):** Nos 3 primeiros pacotes podemos ver o cliente (.130) e o servidor (.132) a realizar um “three-way handshake” TCP para estabelecer uma ligação na porta 389.
 - Este é o método padrão do TCP para o estabelecimento de uma ligação, no qual o cliente inicia com um pedido de sincronização (**SYN**), o servidor responde com a sua própria sincronização e confirmação (**SYN-ACK**), e o cliente finaliza o processo com um último reconhecimento (**ACK**).

1	0.000000	192.168.178.130	192.168.178.132	TCP	66 50442 → 389 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 WS=256 SACK_PERM
2	0.000494	192.168.178.132	192.168.178.130	TCP	66 389 → 50442 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 WS=256 SACK_PERM
3	0.000750	192.168.178.130	192.168.178.132	TCP	54 50442 → 389 [ACK] Seq=1 Ack=1 Win=2102272 Len=0

FIGURA 3 - THREE-WAY HANDSHAKE

- **Autenticação (Pacotes 4 e 6):** O cliente envia um bindRequest para se autenticar como o utilizador " Bob B. Munchies". O servidor responde com bindResponse: success, indicando que a autenticação foi bem-sucedida.

4	0.017491	192.168.178.130	192.168.178.132	LDAP	130 bindRequest(1) "CN=Bob B. Munchies,CN=Users,DC=segsi_domain,DC=local" simple
5	0.019608	192.168.178.132	192.168.178.130	LDAP	76 bindResponse(1) success
6	0.020861	192.168.178.130	192.168.178.132	TCP	54 50442 → 389 [FIN, ACK] Seq=77 Ack=23 Win=2102272 Len=0

FIGURA 4 – AUTENTICAÇÃO

- **Consulta de Informação (Pacotes 12+):** Após a autenticação, o cliente inicia uma fase de enumeração, onde realiza várias consultas (**searchRequest**) para obter informações sobre a estrutura do diretório, incluindo o **RootDSE** e o **Schema** do **Active Directory**.

12 3.697518	192.168.170.130	192.168.170.132	LDAP	130 bindRequest(1) "CN=Bob R. Munchies,OU=Users,DC=segsi_domain,DC=local" simple
13 3.698955	192.168.170.132	192.168.170.130	LDAP	76 bindResponse(1) success
14 3.699255	192.168.170.130	192.168.170.132	TCP	66 50447 → 389 [ACK] Seq=77 Ack=23 Win=2102272 Len=0 SLE=1 SRE=3
15 3.720840	192.168.170.130	192.168.170.132	TCP	66 50447 → 389 [ACK] Seq=77 Ack=23 Win=2102272 Len=0 SLE=1 SRE=3
16 3.841390	192.168.170.130	192.168.170.132	LDAP	112 searchRequest(2) "o=0007" baseObject
17 3.842047	192.168.170.132	192.168.170.130	LDAP	198 searchResultEntry(1) "o=0007" [] searchResultDone(2) success [3 results]
18 3.842052	192.168.170.132	192.168.170.130	TCP	66 50447 → 389 [ACK] Seq=77 Ack=23 Win=2102272 Len=0 SLE=1 SRE=3
19 3.869000	192.168.170.130	192.168.170.132	TCP	66 50447 → 389 [ACK] Seq=77 Ack=23 Win=2102272 Len=0 SLE=1 SRE=3

FIGURA 5 - CONSULTA DE INFORMAÇÃO

```

messageID: 3
protocolOp: searchRequest (3)
  searchRequest
    baseObject: CN=Aggregate,CN=Schema,CN=Configuration,DC=segsi_domain,DC=local
    scope: baseObject (0)
    derefAliases: derefAlways (3)
    sizeLimit: 0
    timeLimit: 0
    typesOnly: False
    Filter: (objectClass=subschema)
    attributes: 7 items
      AttributeDescription: objectClasses
      AttributeDescription: attributeTypes
      AttributeDescription: ldapSyntaxes
      AttributeDescription: matchingRules
      AttributeDescription: matchingRuleUse
      AttributeDescription: createTimestamp
      AttributeDescription: modifyTimestamp
[Response In: 219]

```

FIGURA 6 - PEDIDO 12

- **Transferência de Dados (Pacotes 20+):** Em resposta às consultas, o servidor envia um grande volume de dados, que o **Wireshark** exibe como múltiplos pacotes do tipo **TCP (segment of a reassembled) PDU**.

24 3.974972	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=1625 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
25 3.974972	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=3085 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
26 3.975060	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=4545 Win=2102272 Len=0
27 3.975308	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=4545 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
28 3.975308	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=6005 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
29 3.975357	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=7465 Win=2102272 Len=0
30 3.975580	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=7465 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
31 3.975580	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=8925 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
32 3.975621	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=10385 Win=2102272 Len=0
33 3.975821	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=10385 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
34 3.975821	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=11845 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
35 3.975850	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=13305 Win=2102272 Len=0
36 3.976063	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=13305 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
37 3.976063	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=14765 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
38 3.976084	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=16225 Win=2102272 Len=0
39 3.976290	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=16225 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
40 3.976290	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=17685 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
41 3.976309	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=19145 Win=2102272 Len=0
42 3.976517	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=19145 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
43 3.976517	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=20605 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
44 3.976535	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=22065 Win=2102272 Len=0
45 3.976729	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=22065 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
46 3.976729	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=23525 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
47 3.976750	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=24985 Win=2102272 Len=0
48 3.976924	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=24985 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
49 3.976924	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=26445 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
50 3.976944	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=27905 Win=2102272 Len=0
51 3.977116	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=27905 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
52 3.977116	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=29365 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
53 3.977135	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=30825 Win=2102272 Len=0
54 3.977290	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=30825 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
55 3.977290	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=32285 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
56 3.977309	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=33745 Win=2102272 Len=0
57 3.977459	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=33745 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
58 3.977459	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=35205 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
59 3.977477	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=36665 Win=2102272 Len=0
60 3.977639	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=36665 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
61 3.977639	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=38125 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
62 3.977662	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=39585 Win=2102272 Len=0
63 3.977829	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=39585 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
64 3.977829	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=41045 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
65 3.977852	192.168.170.130	192.168.170.132	TCP	54 50447 → 389 [ACK] Seq=364 Ack=42505 Win=2102272 Len=0
66 3.978007	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=42505 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]
67 3.978007	192.168.170.132	192.168.170.130	TCP	1514 389 → 50447 [ACK] Seq=43965 Ack=364 Win=2102016 Len=1460 [TCP PDU reassembled in 219]

FIGURA 7 - TRANSFERÊNCIA DE DADOS

Problemas de Segurança

- **Problema de Segurança (Crítico):** O grande e principal problema de segurança foi identificado logo no quarto pacote do tráfego, onde após uma pequena análise, conseguimos verificar que o passo de autenticação é realizado e a password é transmitida como texto simples, através de um “**Simple Bind**” permitindo a qualquer pessoa com acesso a esta captura obter acesso total à conta do utilizador. A password, como verificado na imagem abaixo, é “**!!QAZ22wsx**”

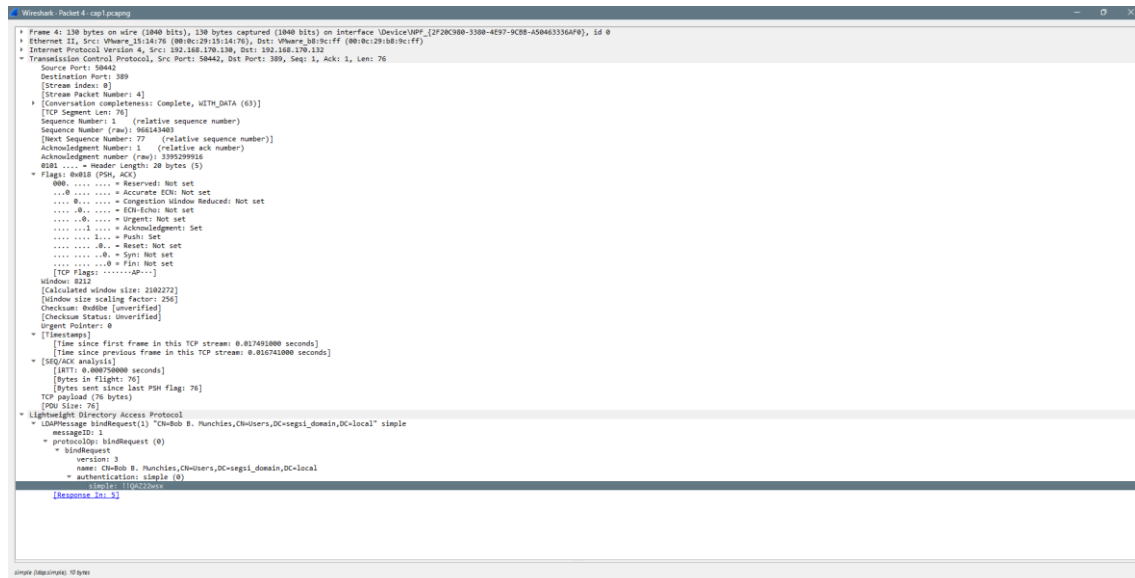


FIGURA 8 - EXPOSIÇÃO DA PASSWORD EM TEXTO CLARO NO PACOTE DE AUTENTICAÇÃO

Mitigações

- Implementar comunicações LDAP seguras, por exemplo **LDAPS** (LDAP sobre SSL/TLS na porta 636) ou a forçar o uso de **StartTLS** na porta 389. Ambos os métodos **encriptam** a comunicação, protegendo as **credenciais** de serem **expostas**, mitigando o problema de segurança.

Outras Considerações

- Divulgação Excessiva de Informação:
 - Após a autenticação bem-sucedida, a captura mostra que o utilizador **Bob B. Munchies** tem permissões de leitura excessivas, permitindo-lhe realizar consultas (**searchRequest**) que enumeram a estrutura completa do **Active Directory**, incluindo o **Schema** e outros **objetos sensíveis**. Esta atividade é evidenciada pelo grande volume de dados transferidos pelo servidor após o login.
 - Juntando isto ao facto de a password ser de acesso tão simples visto que é passado como um texto simples, é de extrema importância rever esse problema visto que qualquer pessoa pode ter acesso a esses dados sensíveis de forma fácil.
 - Deve ser garantido não só que a password não é tão facilmente descoberta, como também que sejam **revistas as permissões (ACLs) no Active Directory** para que um utilizador comum não tenha permissão para ler informações sensíveis da estrutura do diretório, a menos que seja estritamente necessário para as suas funções.

- Outra medida de segurança recomendada é a implementação de **Autenticação Multifator (MFA)**. Mesmo que as credenciais de acesso sejam comprometidas, o uso de um segundo fator de autenticação (como um código enviado por SMS ou através de uma aplicação autenticadora) adiciona uma camada extra de segurança, dificultando que se consiga finalizar o ataque e protegendo os dados do domínio.

Captura 2 – CAP2.cap – Pedro Coelho - 1240485

Intervenientes

- **Cliente:** 192.168.2.100 (um dispositivo na rede local), autenticado com o email test2@colasoft.com
- **Servidor:** 64.246.26.20 (um servidor remoto) de serviço de emails: mail.colasoft.com

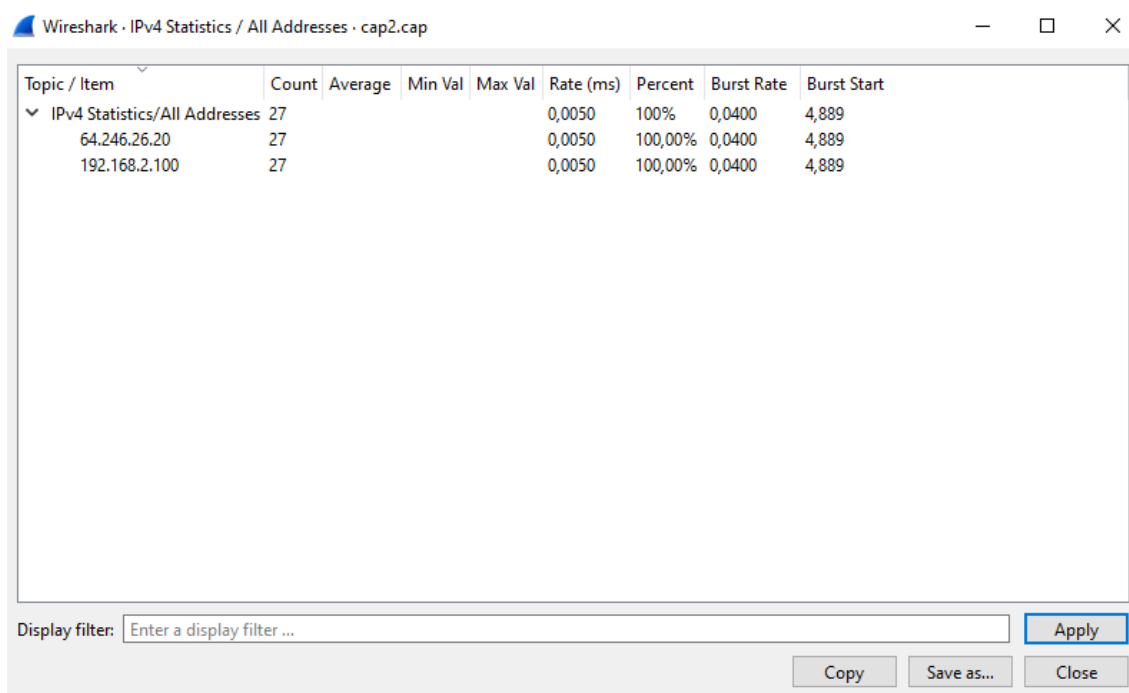


FIGURA 9 - INTERVENIENTES CAP 2

4	0.934000	64.246.26.20	192.168.2.100	POP	106[S: +OK POP3 mail.colasoft.com v2001.78rh server ready
---	----------	--------------	---------------	-----	---

FIGURA 10 - SERVIÇO DE EMAILS DO SERVIDOR

5	0.937000	192.168.2.100	64.246.26.20	POP	79[C: USER test2@colasoft.com
---	----------	---------------	--------------	-----	-------------------------------

FIGURA 11 - EMAIL IDENTIFICADOR DO CLIENTE/UTILIZADOR

Protocolo Principal

O protocolo principal utilizado é o **POP3** (Post Office Protocol v3), como é possível ver na captura a partir da linha 4. É um protocolo amplamente utilizado em sistemas de emails, que permite ao utilizador descarregar emails de um servidor (remoto) para o dispositivo local. Funciona sobre o protocolo **TCP** e opera num modelo cliente-servidor, onde o cliente pode realizar solicitações sobre o conteúdo da caixa de correio. É considerado um protocolo “pull” onde o cliente inicia as conexões e é sempre o responsável por requisitar as mensagens.

Apesar de ser eficiente para transferir emails, este protocolo apresenta imensas limitações em termos de segurança, sendo a mais evidente o facto da comunicação ser transmitida em texto simples, o que torna todo o sistema suscetível a captura de dados sensíveis, possibilitando ataques a qualquer interveniente que tenha acesso às capturas.

Operações realizadas pelo protocolo principal

Estabelecimento da Ligação e Boas-Vindas (Pacotes 1-4):

- Após o three-way handshake TCP, o servidor (64.246.26.20) envia uma mensagem de boas-vindas no Pacote 4, confirmando que o serviço POP3 está pronto (+OK POP3 mail.colasoft.com...).

Autenticação (Pacotes 5-10):

- O cliente (192.168.2.100) envia o nome de utilizador com o comando USER test2@colasoft.com (Pacote 5).
- O servidor aceita o utilizador (+OK User name accepted..., Pacote 7).
- O cliente envia a palavra-passe com o comando PASS test2123 (Pacote 8).
- O servidor confirma a autenticação e abre a caixa de correio (+OK Mailbox open, 1 messages, Pacote 10).

Consulta da Caixa de Correio (Pacotes 11-18):

- O cliente verifica o estado da caixa com STAT (Pacote 11), recebendo a resposta +OK 1 984 (Pacote 13), indicando 1 mensagem com 984 bytes.
- O cliente pede os identificadores únicos com UIDL (Pacote 14), recebendo a lista no Pacote 16.
- O cliente pede a lista de mensagens com LIST (Pacote 17), recebendo a confirmação no Pacote 18.

Transferência do Email (Pacotes 19-20):

- O cliente solicita o download da primeira (e única) mensagem com RETR 1 (Pacote 19).
- O servidor envia a confirmação (+OK 984 octets) e o conteúdo completo do email no Pacote 20.

Limpeza e Encerramento (Pacotes 21-24):

- O cliente marca a mensagem descarregada para eliminação no servidor com DELE 1 (Pacote 21).
- O servidor confirma a eliminação (+OK Message deleted, Pacote 22).
- O cliente envia o comando para terminar a sessão, QUIT (Pacote 23).
- O servidor despede-se com +OK Sayonara (Pacote 24).

Fecho da Ligação TCP (Pacotes 25-27):

- Cliente e servidor encerram a ligação TCP de forma ordenada.

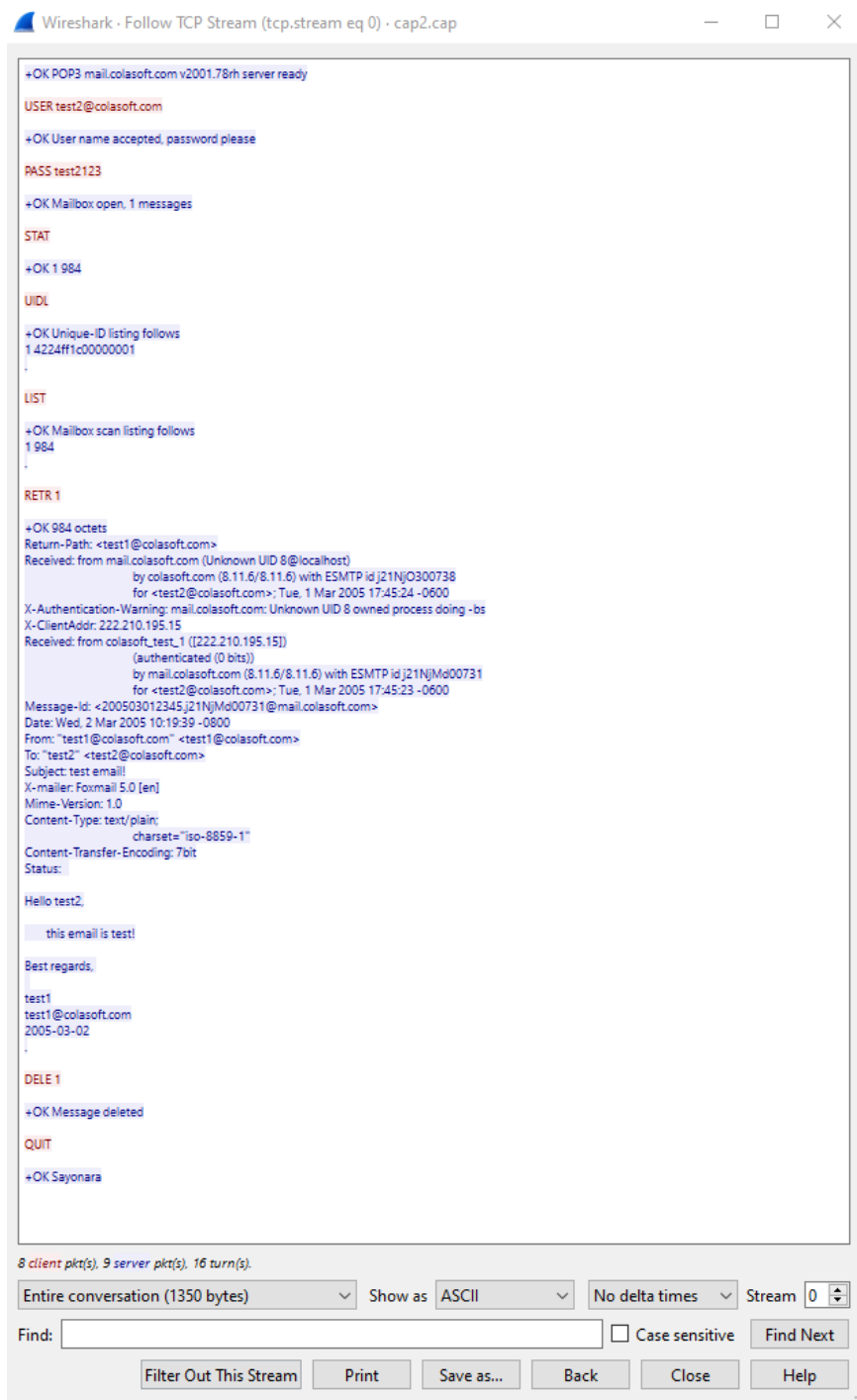


FIGURA 12 - CAPTURA DO FOLLOW TCP STREAM

Problemas de Segurança

- **Problema 1 (Crítico):** Credenciais em Texto Claro.
 - **Descrição:** Toda a comunicação, incluindo a fase de autenticação, ocorre sem qualquer tipo de encriptação. A palavra-passe do utilizador, test2123, é transmitida em texto simples e legível através da rede com o comando PASS (visível no Pacote 8 da captura geral e no fluxo TCP).
 - **Impacto:** Qualquer pessoa que intercete este tráfego (utilizando ferramentas como o Wireshark) pode facilmente roubar as credenciais de acesso à caixa de correio do utilizador, comprometendo a confidencialidade e permitindo acessos não autorizados.

- **Problema 2 (Crítico):** Conteúdo dos Emails em Texto Claro.
 - **Descrição:** Após a autenticação, o conteúdo completo do email (cabeçalhos, assunto e corpo da mensagem) é transferido sem encriptação, em resposta ao comando RETR 1 (visível no Pacote 20 da captura geral e no fluxo TCP).
 - **Impacto:** Isto representa uma grave violação da confidencialidade da comunicação. Qualquer pessoa na rede pode interceptar e ler o conteúdo dos emails do utilizador.

Mitigações

A solução fundamental para estas vulnerabilidades é a utilização de protocolos que garantam a encriptação de toda a sessão:

- **POP3S (POP3 sobre SSL/TLS):** Configurar o cliente e o servidor para utilizarem POP3S, que encapsula toda a comunicação POP3 num túnel seguro SSL/TLS, tipicamente na porta 995. Isto protege tanto as credenciais como o conteúdo dos emails.
- **IMAPS (IMAP sobre SSL/TLS):** Considerar a migração para IMAPS (porta 993), uma alternativa mais moderna e flexível ao POP3, que também fornece encriptação de ponta a ponta para a sessão.

Outras Considerações

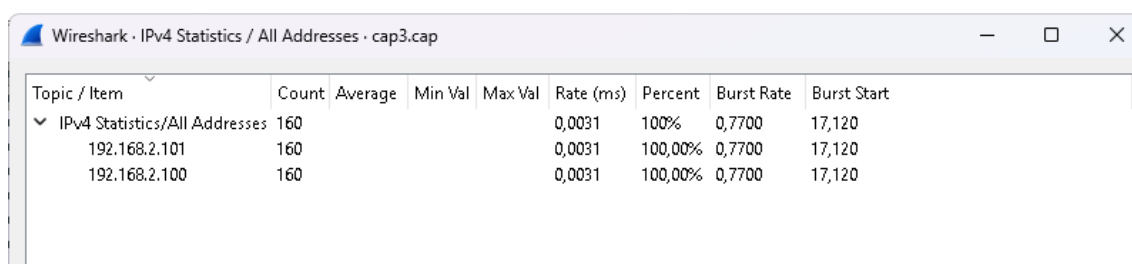
- No mesmo pensamento da primeira captura, e tendo em conta um dos problemas de segurança ser o mesmo, relativamente à password ser exibida em texto num dos pacotes, a implementação de **Autenticação Multifator (MFA)** poderia ser benéfica. Dessa forma, mesmo que as credenciais de acesso sejam comprometidas, o uso de um segundo fator de autenticação (como um código enviado por SMS ou através de uma aplicação autenticadora) adiciona uma camada extra de segurança, dificultando que se consiga finalizar o ataque e protegendo os dados do utilizador.

Captura 3 – CAP3.cap – Pedro Ferreira - 1201172

Intervenientes

São claramente identificados 2 *hosts* intervenientes:

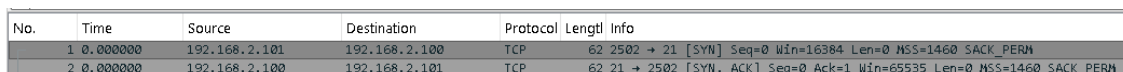
- Host A: 192.168.2.101
- Host B: 192.168.2.100



Topic / Item	Count	Average	Min Val	Max Val	Rate (ms)	Percent	Burst Rate	Burst Start
IPv4 Statistics/All Addresses	160				0,0031	100%	0,7700	17,120
192.168.2.101	160				0,0031	100,00%	0,7700	17,120
192.168.2.100	160				0,0031	100,00%	0,7700	17,120

FIGURA 13 ESTATÍSTICAS IPV4 NA CAPTURA 3

Ambos os hosts comunicam pela porta 21, que é designada para o *File Transfer Protocol (FTP)*, mas também por portas TCP temporárias (superiores à porta 1024).



No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.2.101	192.168.2.100	TCP	62	2502 → 21 [SYN] Seq=0 Win=16384 Len=0 MSS=1460 SACK_PERM
2	0.000000	192.168.2.100	192.168.2.101	TCP	62	21 → 2502 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 SACK_PERM

FIGURA 14 EXEMPLO DE COMUNICAÇÃO PROTOCOLO FTP & TCP -IMAGEM 1

18 7.784000	192.168.2.100	192.168.2.101	TCP	62 20 → 2504 [SYN] Seq=0 Win=65535 Len=0 MSS=1460 SACK_PERM
19 7.784000	192.168.2.101	192.168.2.100	TCP	62 2504 → 20 [SYN, ACK] Seq=0 Ack=1 Win=17520 Len=0 MSS=1460 SACK_PERM

FIGURA 15 EXEMPLO DE COMUNICAÇÃO PROTOCOLO FTP & TCP - IMAGEM 2

Protocolo Principal

Na sequência da informação anterior exposta, o principal protocolo utilizado é o FTP, associado à porta 21 (para controlo), e portas dinâmicas para a transferência de dados.

Este é um protocolo não encriptado, usado apenas para a transferência de ficheiros e autenticação básica (User & Pass)

Adicionalmente, como explicado anteriormente, percebe-se à alocação de portas para comunicação TCP.

Wireshark - Protocol Hierarchy Statistics - cap3.cap										
Protocol	Percent Packets	Packets	Percent Bytes	Bytes	Bits/s	End Packets	End Bytes	End Bits/s	PDU's	
▼ Frame	100.0	160	100.0	80447	12 k	0	0	0	160	
▼ Ethernet	100.0	160	3.2	2540	388	0	0	0	160	
▼ Internet Protocol Version 4	100.0	160	4.0	3200	489	0	0	0	160	
▼ Transmission Control Protocol	100.0	160	4.1	3296	503	75	1596	243	160	
▼ FTP Data	32.5	52	87.5	70403	10 k	48	69676	10 k	52	
Line-based text data	2.5	4	0.9	727	111	4	727	111	4	
File Transfer Protocol (FTP)	20.6	33	1.3	1008	154	33	1008	154	33	

FIGURA 16 ESTATÍSTICAS DA HIERARQUIA DE PROTOCOLO DA CAPTURA 3

Operações realizadas pelo protocolo principal

Entidades e Iniciação da Comunicação

- Cliente: 192.168.2.101
- Servidor: 192.168.2.100 (identificado como “Microsoft FTP Service” no banner inicial)

A comunicação é iniciada pelo cliente, que abre uma conexão TCP ao servidor na porta 21, destinada ao canal de controlo.

O servidor responde com uma mensagem de boas-vindas (220), indicando que está pronto a aceitar comandos.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	192.168.2.101	192.168.2.100	TCP	62	2502 → 21 [SYN] Seq=0 Win=16384 Len=0 MSS=1460 SACK_PERM
2	0.000000	192.168.2.100	192.168.2.101	TCP	62	21 → 2502 [SYN, ACK] Seq=0 Ack=1 Win=65535 Len=0 MSS=1460 SACK_PERM
3	0.000000	192.168.2.101	192.168.2.100	TCP	60	2502 → 21 [ACK] Seq=1 Ack=1 Win=17520 Len=0
4	0.001000	192.168.2.100	192.168.2.101	FTP	112	Response: 220 colasoft_test_2 Microsoft FTP Service (Version 5.0).

FIGURA 17 ESTABELECIMENTO DA COMUNICAÇÃO ENTRE CLIENTE E SERVIDOR

Fluxo inicial

- 192.168.2.101 → 192.168.2.100:21 [SYN] – pedido de ligação TCP (início da sessão).
- 192.168.2.100 → 192.168.2.101 [SYN, ACK] – servidor aceita a ligação.
- 192.168.2.101 → 192.168.2.100 [ACK] – cliente confirma (handshake completo).
- 220 colasoft_test_2 Microsoft FTP Service – resposta inicial do servidor FTP.

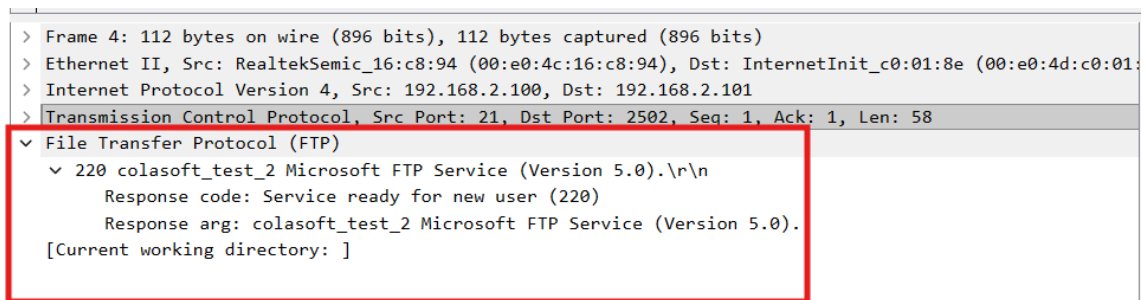


FIGURA 18 MENSAGEM DE CONFIRMAÇÃO DO SERVIDOR DE ACESSIBILIDADE DOS SERVIÇOS PARA O CLIENTE
Autenticação e Negociação

Após a conexão ser estabelecida:

- O cliente envia o comando USER <nome_utilizador>.
- O servidor responde com 331 Password required for <nome_utilizador>.
- O cliente envia PASS <palavra_passe>.
- O servidor confirma o login com 230 User logged in.

6	3.996000	192.168.2.101	192.168.2.100	FTP	74 Request: USER administrator
7	3.997000	192.168.2.100	192.168.2.101	FTP	96 Response: 331 Password required for administrator.
8	4.163000	192.168.2.101	192.168.2.100	TCP	60 2502 → 21 [ACK] Seq=21 Ack=101 Win=17420 Len=0
9	6.108000	192.168.2.101	192.168.2.100	FTP	67 Request: PASS 123456
10	6.111000	192.168.2.100	192.168.2.101	FTP	97 Response: 230-Welcome to colasoft_test site,thanks!

FIGURA 19 AUTENTICAÇÃO DO CLIENTE NO SERVIDOR ATRAVÉS DO FTP

Note-se que os atributos USER e PASS referentes à autenticação são enviados em *plain text*, sujeitos a que qualquer utilizador da rede tenha acesso a estas credenciais.

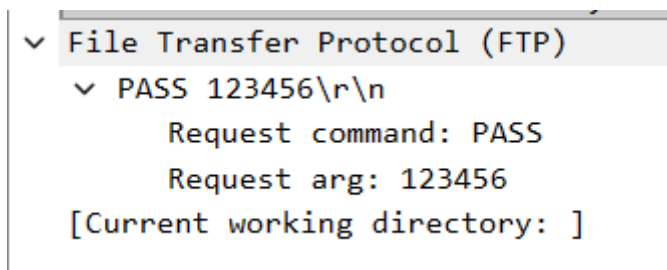


FIGURA 20 VISIBILIDADE DE DADOS SENSÍVEIS NO PROCESSO DE AUTENTICAÇÃO DO CLIENTE NO SERVIDOR
Comunicação e Transferência de Dados

Após o login, o cliente executa comandos típicos de sessão FTP, que ocorrem no canal de controlo (porta 21), mas que abrem canais de dados adicionais (portas dinâmicas) para a transferência de ficheiros.

Exemplos:

- LIST → o cliente pede a listagem de diretórios.

31	9.451000	192.168.2.101	192.168.2.100	FTP	60 Request: LIST
----	----------	---------------	---------------	-----	------------------

FIGURA 21 EXEMPLO DE COMANDO LIST ATRAVÉS DO FTP

- RETR <ficheiro> → o cliente pede a transferência de um ficheiro do servidor.

46	17.124000	192.168.2.101	192.168.2.100	FTP	73	Request: RETR logagent.exe
----	-----------	---------------	---------------	-----	----	----------------------------

FIGURA 22 EXEMPLO DO COMANDO RETR ATRAVÉS DO FTP

- XPWD → o cliente pede uma listagem dos diretórios e o servidor devolve o diretório de trabalho atual (este comando representa um extensão do PWD).

143	48.684000	192.168.2.101	192.168.2.100	FTP	60	Request: XPWD
144	48.685000	192.168.2.100	192.168.2.101	FTP	85	Response: 257 "/" is current directory.

FIGURA 23 EXEMPLO DO COMANDO XPWD ATRAVÉS DO FTP

- NLST → Permite uma listam dos ficheiros disponíveis (apenas o nome, por oposição ao LIST que apresenta uma lista detalhada).

148	52.015000	192.168.2.101	192.168.2.100	FTP	60	Request: NLST
149	52.016000	192.168.2.100	192.168.2.101	FTP	109	Response: 150 Opening ASCII mode data connection for file list.

FIGURA 24 EXEMPLO DO COMANDO NLST ATRAVÉS DO FTP

```
[Current working directory: /]
v Line-based text data (6 lines)
  laprxy.dll\r\n
  logagent.exe\r\n
  mplayer2.exe\r\n
  npds.zip\r\n
  npdsplay.dll\r\n
  npwmsdrm.dll\r\n
```

FIGURA 25 RESPOSTA DE LISTAGEM DO SERVIDOR AO COMANDO NLST

Características da comunicação:

- Modo de operação:
 - Pelo padrão FTP e pela sequência de sequências de endereços observados, presume-se que se trata de um modo ativo de comunicação (os pedidos PORT reforçam esta ideia).
- Controle e dados separados:
 - Porta 21 – comandos e respostas.
 - Portas dinâmicas – transferência de dados.
- Ordem e confiabilidade: garantidas pelo TCP.
- Sem encriptação: conteúdo (comandos e dados) visível no tráfego.

Problemas de Segurança

- Credenciais em texto claro — o FTP transmite USER e PASS sem encriptação.

- Comunicação sem encriptação — o conteúdo dos ficheiros transferidos também pode ser interceptado.
- Ausência de autenticação robusta — sem mecanismos de MFA, certificados, ou verificação de integridade.
- Possibilidade de ataque de escuta (sniffing) — qualquer atacante na mesma rede pode capturar credenciais.

Mitigações

- Substituir FTP por SFTP (FTP sobre SSH) ou FTPS (FTP com TLS).
- Restringir acesso à porta 21 em firewalls, permitindo apenas IPs autorizados.
- Implementar monitorização de tráfego e alertas para conexões FTP não autorizadas.
- Encriptar credenciais e comunicações — usar SSH, TLS ou VPN.
- Educar utilizadores sobre riscos de usar protocolos legados.

Outras Considerações

- O tráfego parece ser controlado (possivelmente um teste de rede);
- A presença de apenas dois hosts e poucos pacotes sugere uma sessão curta;
- Caso tenha sido em ambiente de produção, existe risco sério de exposição de dados.

Captura 4 – CAP4.cap – Pedro Ferreira - 1201172

Intervenientes

- Host A (Cliente): 192.168.251.1
- Host B (Servidor): 192.168.251.11

Portas utilizadas:

- TCP 23 (porta padrão do protocolo TELNET);
- Algumas comunicações adicionais NBNS (porta 137 UDP);

Topic / Item	Count	Average	Min Val	Max Val	Rate (ms)	Percent	Burst Rate	Burst Start
▼ IPv4 Statistics/All Addresses	242				0,0054	100%	0,0700	4,519
192.168.251.11	242				0,0054	100,00%	0,0700	4,519
192.168.251.1	242				0,0054	100,00%	0,0700	4,519

Protocolo Principal

O Telnet (RFC 854) é um protocolo de comunicação remota baseado em texto que permite o acesso interativo a dispositivos ou sistemas; opera sobre a camada de transporte TCP (porta 23) e fornece comunicação bidirecional e síncrona em modo terminal. Durante o estabelecimento da sessão, o Telnet envia caracteres ASCII entre cliente e servidor e negocia opções de terminal através de comandos de controlo ("WILL", "DO", "WON'T", "DON'T").

Protocol	Percent Packets	Packets	Percent Bytes	Bytes	Bits/s	End Packets	End Bytes	End Bits/s	PDUs
▼ Frame	100.0	242	100.0	18585	3289	0	0	0	242
▼ Ethernet	100.0	242	18.2	3388	599	0	0	0	242
▼ Internet Protocol Version 4	100.0	242	26.0	4840	856	0	0	0	242
▼ User Datagram Protocol	2.1	5	0.2	40	7	0	0	0	5
NetBIOS Name Service	1.2	3	0.8	150	26	3	150	26	3
Dynamic Host Configuration Protocol	0.8	2	3.3	608	107	2	608	107	2
▼ Transmission Control Protocol	96.7	234	40.4	7508	1328	86	2772	490	234
Telnet	61.2	148	9.6	1793	317	148	1793	317	148
Internet Control Message Protocol	1.2	3	1.4	258	45	3	258	45	3

- TELNET transmite tudo (incluindo passwords) sem encriptação, ou seja, um atacante na mesma rede pode ler as credenciais em segundos.
- A fase de negociação de opções é aberta, permitindo inserção de comandos maliciosos ou manipulação de sessão (ex.: Telnet option injection).
- Pacotes podem ser modificados durante a transmissão sem detecção, sujeito a Man In the Middle Attack (MITM),
- Não existe verificação de integridade

- **Utilizador autenticado:** bob (atributo RADIUS User-Name).

[illegible]

- **Attribute vendor-specific provider:** Microsoft (Vendor-ID 311) — uso de MS-CHAP (MS-CHAP-Response/Challenge) e MS-MPPE attributes.

FIGURA 30 - ATTRIBUTE VENDOR-SPECIFIC PROVIDER MS CHAP/MPPE

Linhas da captura:

- Access-Request (frame 1): User-Name: bob, NAS-IP-Address: 192.168.170.135, NAS-Identifier: pfSense.home.arp, MS-CHAP VSA presentes.
- Access-Accept (frame 2): resposta do servidor RADIUS Access-Accept id=240 com VSAs MS-CHAP-MPPE-Keys e MS-MPPE-Encryption-Types (RC4-40-128).

Protocollo Principale

Protocolo: RADIUS (Remote Authentication Dial-In User Service) sobre UDP (porta destino 1812).

Sub-protocolo/autenticação usada na sessão: MS-CHAP (Vendor-Specific Microsoft)

attributes) — ou seja, autenticação tipo MS-CHAPv2 (ou MS-CHAP family) transportada dentro do RADIUS. O fluxo mostra um Access-Request com MS-CHAP-Response e um Access-Accept contendo MS-CHAP-derived MPPE keys.

Identificadores:

- RADIUS Code: Access-Request (1) e Access-Accept (2).
- Vendor-Specific Microsoft attributes: MS-CHAP-Response, MS-CHAP-Challenge, MS-CHAP-MPPE-Keys, MS-MPPE-Encryption-Types.

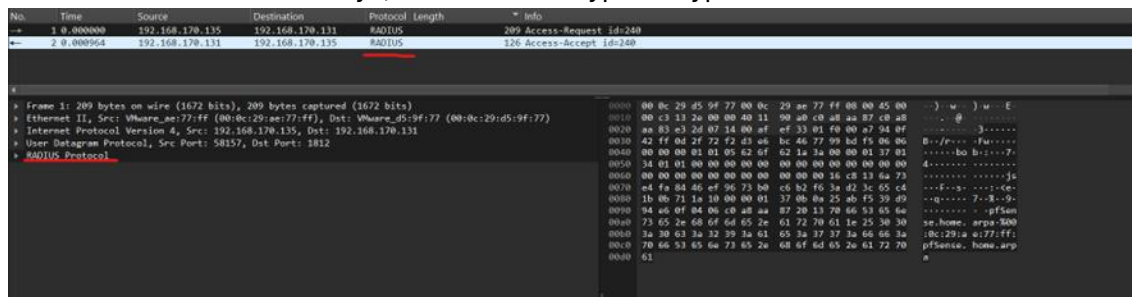


FIGURA 31 - PROTOCOLO

Operações realizadas pelo protocolo principal

1. O NAS (192.168.170.135) envia um **Access-Request** ao servidor RADIUS (192.168.170.131), identificador id=240.
 - a. A mensagem contém: User-Name: bob, Service-Type: Login, NAS-Identifier: pfSense.home.arpa, NAS-IP-Address: 192.168.170.135, Called-Station-Id e Vendor-Specific (Microsoft) atributos incluindo MS-CHAP-Response e um MS-CHAP-Challenge.
 - b. O Access-Request tem Authenticator (Request Authenticator) — usado para protecção de alguns atributos e para calcular HMACs/encodings.

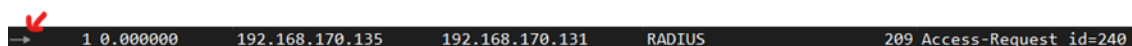


FIGURA 32 - TIPO DE PEDIDO: ID

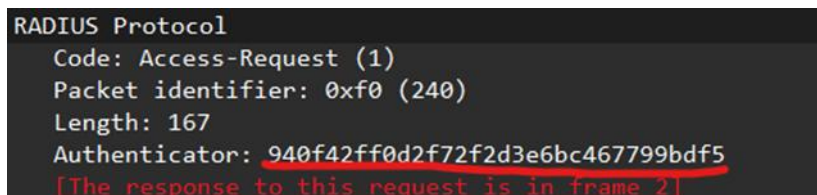


FIGURA 33 - AUTENTICADOR

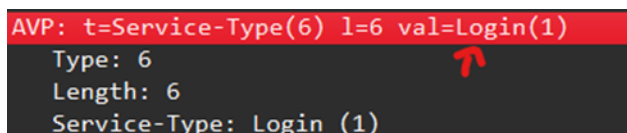


FIGURA 34 - TIPO DE PEDIDO: LOGIN

2. O servidor RADIUS processa a autenticação MS-CHAP e responde com **Access-Accept** (mesmo id=240) em 0.000964s.
 - a. A resposta inclui VSAs Microsoft com MS-CHAP-MPPE-Keys (decrypted value mostrado na dissecação) e políticas de encriptação MS-MPPE-Encryption-Policy e MS-MPPE-Encryption-Types (RC4-40-128).
 - b. A presença de MS-CHAP-MPPE-Keys demonstra que o servidor derivou uma ou mais chaves para a criptografia do túnel/ligação (por exemplo, para PPP over Ethernet/VPN/802.1X) e as incluiu na resposta de aceitação.

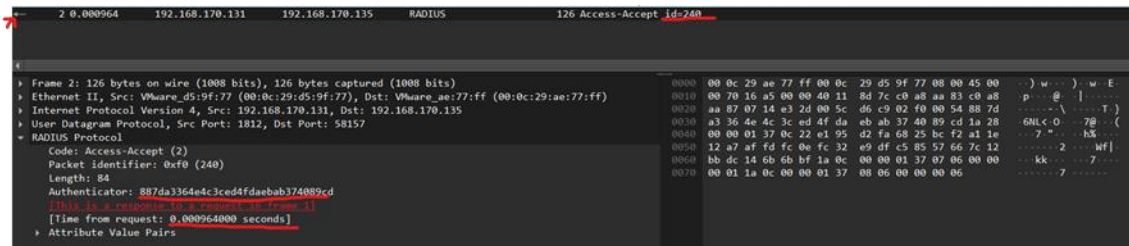


FIGURA 35 - AUTENTICADOR E TEMPO DE RESPOSTA (SEGUNDOS)

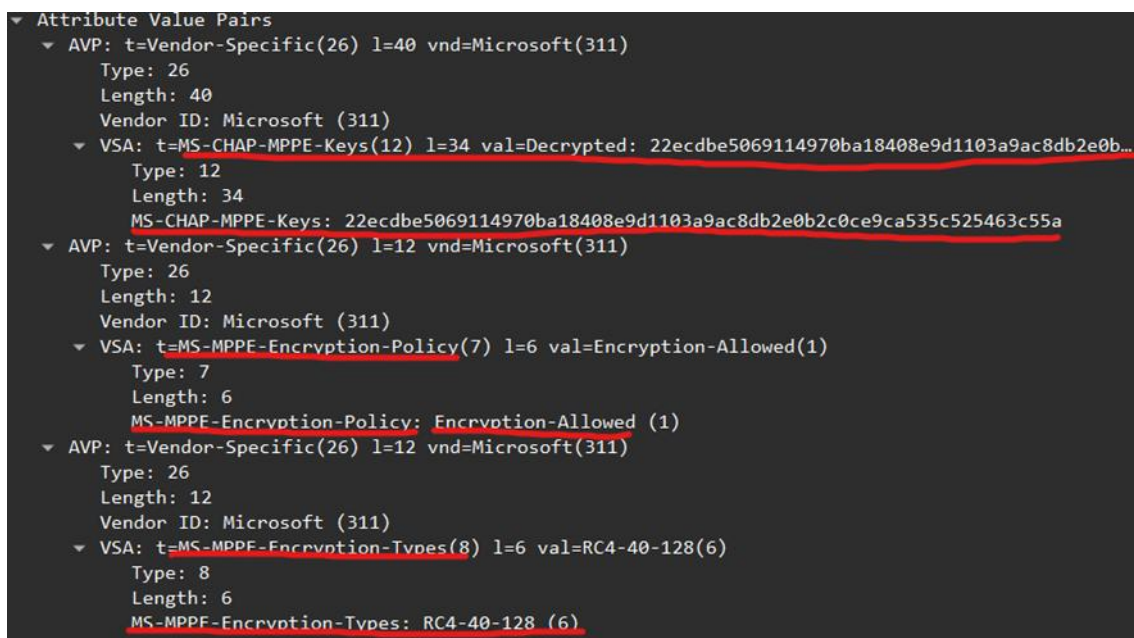


FIGURA 36 - MS-CHAP-MPPE-KEYS, MS-MPPE-ENCRYPTION-POLICY E MS-MPPE-ENCRYPTION-TYPES

Observações técnicas:

- O id do pedido/resposta coincide (id=240) → resposta corresponde à requisição.
- Comunicação por UDP/1812 padrão RADIUS.
- MS-CHAP Challenge/Response indica que a autenticação é baseada em challenge (hashes) específico da família Microsoft.

Resumo técnico:

TABELA 1 - RESUMO TÉCNICO RADIUS

Campo	Valor / Significado
User-Name	bob
Protocolo de autenticação	MS-CHAPv2 (via RADIUS)
Password	Está protegida (hash derivado)
Resultado	Login bem-sucedido (Access-Accept)
Servidor RADIUS	192.168.170.131
Cliente RADIUS (NAS)	192.168.170.135 (pfSense.home.arpa)
Encriptação	MPPE RC4-40-128

Problemas de Segurança

A. Uso de MS-CHAP / MS-CHAPv2

- **Problema:** MS-CHAP (especialmente MS-CHAPv2) é considerado fraco perante ataques offline: as fragilidades conhecidas permitem que um atacante recupere a palavra-passe com um ataque de força bruta combinado com a quebra do DES (muito documentado).
- **Risco:** Alguém que capture o Access-Request (com MS-CHAP-Response) pode, se tiver recursos, tentar ataques offline e descobrir as credenciais do utilizador. Se obtiver a palavra-passe, poderá autenticar-se em serviços que dependem desse RADIUS.

[illegible]

FIGURA 37 - MS-CHAP CHALLENGE - RESPONSE

B. Transporte RADIUS sem proteção (UDP sem TLS/IPsec)

- **Problema:** O RADIUS aqui corre sobre UDP sem protecção do transporte (não há RADIUS-over-TLS/RadSec visível). Pacotes RADIUS contêm atributos sensíveis (MS-CHAP-Response, MPPE keys).
- **Risco:** Intercepção da rede (man-in-the-middle, sniffing) permite capturar os atributos e derivar chaves/credenciais; se shared secret fraco, é trivial obter MPPE keys a partir do payload.~

C. MPPE / RC4-40-128

- **Problema:** A resposta indica MS-MPPE-Encryption-Types: RC4-40-128 (6) e MS-MPPE-Encryption-Policy: Encryption-Allowed. RC4 e especialmente 40-bit são fracos por definições modernas.
- **Risco:** Mesmo quando MPPE é usado para proteger tráfego PPP, uso de RC4 com chave de 40 bits é insuficiente — possíveis ataques de recuperação de tráfego.

D. MPPE keys visíveis no dump

- **Problema:** No dump o dissector mostrou MS-CHAP-MPPE-Keys com “Decrypted: ...” — isto indica que a ferramenta de análise (Wireshark) foi capaz de mostrar o conteúdo porque a encriptação do atributo RADIUS foi reversível na análise (por exemplo Wireshark pode decodificar se tiver o shared secret ou se o atributo estiver em forma facilmente decodificável).
- **Risco:** Se alguém tiver acesso às chaves/secret, consegue obter as MPPE keys; sua exposição facilita decriptação de tráfego subsequente.

E. Shared secret e configuração de clientes

- **Problema potencial:** Se os NAS/servidor usarem shared secrets fracos ou não específicos por NAS, compromete todo o sistema AAA.
- **Risco:** Compromisso de secret permite manipular autenticações, criar Access-Accept falsos, e decriptar atributos sensíveis.

Mitigações

1. Substituição de MS-CHAPv2

- **O que trocar:** MS-CHAPv2 → EAP-TLS ou PEAP-TLS
- **Problema que resolve:** Vulnerabilidade a ataques offline que permitem recuperar passwords a partir de hashes capturados
- **Porquê:** EAP baseado em certificados elimina a transmissão de hashes dependentes da password, tornando ataques offline impraticáveis

2. Proteção do transporte RADIUS

- **O que trocar:** RADIUS sobre UDP não protegido → RADIUS-over-TLS (RadSec) ou túnel VPN/IPsec
- **Problema que resolve:** Captura de pacotes sensíveis (MS-CHAP-Response, MPPE keys) em trânsito
- **Porquê:** TLS/IPsec garante confidencialidade e integridade, prevenindo sniffing ou ataques man-in-the-middle

3. Atualização de cifras MPPE

- **O que trocar:** RC4-40/128 → AES ou RC4 $\geq$ 128 bits (quando MPPE for necessário)
- **Problema que resolve:** Fraqueza de RC4 40-bit, vulnerável a ataques de recuperação de tráfego
- **Porquê:** Cifras modernas fornecem proteção adequada para tráfego PPP

4. Fortalecimento de shared secrets

- **O que trocar:** Shared secrets fracos ou reutilizados → secrets fortes, aleatórios, únicos por NAS (≥ 16 caracteres)
- **Problema que resolve:** Compromisso do secret permite forjar Access-Accept ou decriptar atributos sensíveis
- **Porquê:** Secrets fortes e exclusivos impedem ataques de engenharia e exposição de MPPE keys

5. Políticas de passwords e gestão de credenciais

- **O que trocar:** Senhas fracas ou estáticas → senhas fortes, auditoria e rotação periódica
- **Problema que resolve:** Ataques offline e exploração de credenciais fracas
- **Porquê:** Senhas complexas aumentam significativamente o tempo necessário para quebrar hashes capturados

Outras Observações

- A captura confirma que a autenticação RADIUS funcionou corretamente, mas evidencia riscos de segurança associados ao protocolo e à configuração atual.
- Mesmo sem intercetação ativa, atributos sensíveis (como MS-CHAP-MPPE-Keys) podem ser expostos se houver acesso ao shared secret.
- O uso de MS-CHAPv2 e cifras fracas indica que, embora a autenticação tenha ocorrido com sucesso, a confidencialidade e integridade do tráfego não estão totalmente garantidas.
- A proteção da infraestrutura depende não apenas do protocolo, mas também de políticas de senha fortes, secrets robustos e transporte seguro entre NAS e servidor.
- Recomenda-se atenção contínua à atualização de protocolos e à segregação de rede para reduzir a superfície de ataque.

Captura 6 – CAP6.pcap – Pedro Moreira – 1211138

Intervenientes

- **Origem (Possível Cliente ou Scanner):** 218.232.95.60 — origem externa, IP público, possivelmente pertencente a uma rede fora do domínio interno.
- **Destino (Servidor Interno):** 192.168.1.4 — máquina da rede local.
- **Endereços MAC:**
 - Origem: 11:22:33:44:55:66
 - Destino: de:ad:ca:fe:ba:be
- **Portas:**
 - UDP origem: 3664
 - UDP destino: 1434 (porta associada normalmente ao serviço Microsoft SQL Server Browser).

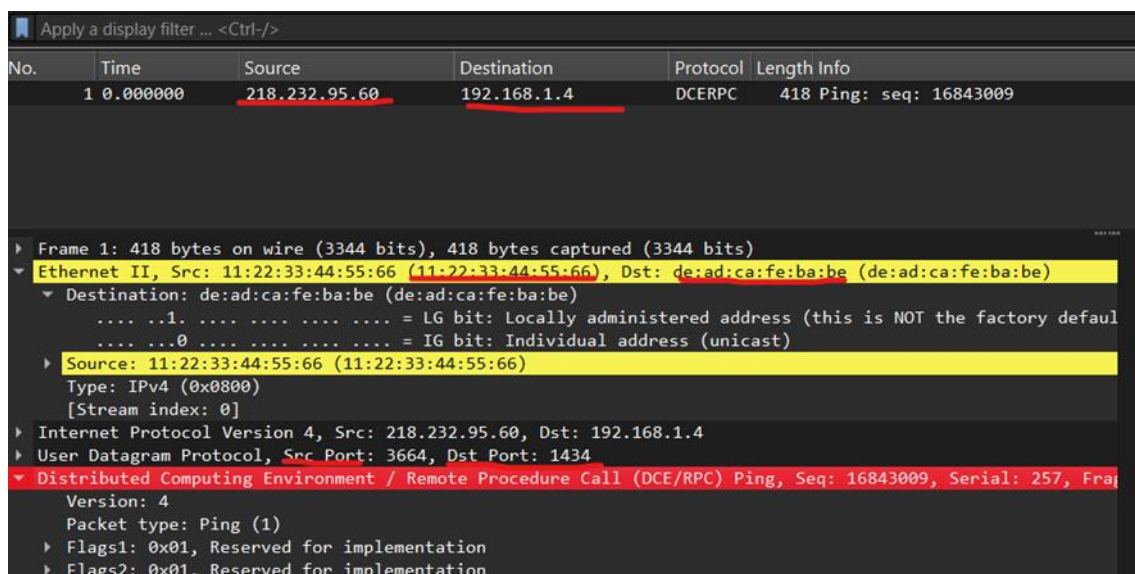


FIGURA 38 - ORIGEM E DESTINO PING DCERPC

Protocolo Principal

- **Protocolo:** DCERPC (Distributed Computing Environment / Remote Procedure Call) sobre UDP.
- **Porta de destino:** 1434 — habitualmente utilizada por serviços Microsoft para descoberta de instâncias SQL Server (MS-SQL Browser).
- **Função do pacote:** “Ping” (mensagem de verificação de conectividade ou teste de presença de interface DCERPC).
- **Autenticação:** Indica *Auth proto: Kerberos 5*, embora não se observe troca de tokens Kerberos — apenas um cabeçalho de verificação.

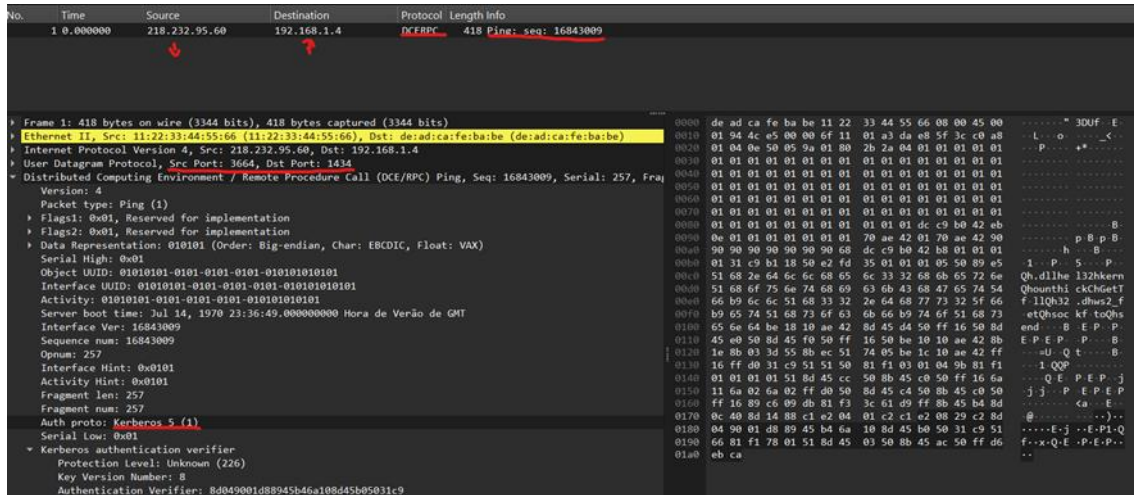


FIGURA 39 - PROTOCOLO DE AUTENTICAÇÃO KERBEROS

Operações realizadas pelo protocolo principal

1. Envio da requisição:

- Host 218.232.95.60 envia um DCE/RPC Ping para 192.168.1.4.
- A mensagem inclui campos de controle, UUIDs e informações de fragmentação (Seq num, Fragment len, Fragment num).
- Indica teste de interface ou sondagem de endpoint RPC.

2. Recepção e processamento:

- Servidor 192.168.1.4 recebe o pacote na porta UDP 1434.
- A autenticação Kerberos 5 é indicada, mas nesta captura não se vê handshake completo.

Auth proto: Kerberos 5 (1)

FIGURA 40 - KERBEROS 5

- Trata-se de ping / teste de disponibilidade.

Info
Ping: seq: 16843009

FIGURA 41 - PING

Problemas de Segurança

- **Exposição de serviço RPC/UDP:** Porta 1434 visível para rede externa, podendo ser alvo de sondagem ou exploração.

- **DCE/RPC não cifrado:** Mensagens e UUIDs viajam em claro; mesmo que contenham autenticação Kerberos é possível mapear interfaces.
- **Fingerprinting:** O padrão dos UUIDs (01010101...) indica teste ou exploração automatizada, comum em varreduras de rede.

```
Object UUID: 01010101-0101-0101-0101-010101010101
Interface UUID: 01010101-0101-0101-0101-010101010101
```

FIGURA 42 - FINGERPRINTING PADRÃO UUID

- **Possível abuso de Kerberos:** Embora a autenticação seja Kerberos, mensagens de ping RPC podem ser usadas para enumerar serviços antes de tentativas de ataque.

Mitigações

1. **Filtragem de portas externas:** Bloquear UDP/1434 para redes públicas, permitindo acesso apenas de hosts confiáveis.
2. **Segregação de rede:** Colocar servidores que oferecem serviços RPC internos em VLANs isoladas.
3. **Monitorização de tráfego:** Alertar para sondagens ou pacotes de teste DCE/RPC vindos de endereços externos.
4. **Atualização e hardening de serviços RPC:** Aplicar patches de segurança no servidor e limitar interfaces RPC expostas.
5. **Autenticação reforçada:** Continuar a usar Kerberos ou outro mecanismo seguro para autenticação de serviços, evitando fallback para NTLM ou protocolos fracos.

Outras Observações

- A captura sugere **atividade de teste (ping) ou sondagem de rede** vindo de 218.232.95.60.
- A utilização de DCE/RPC Ping com UUIDs padrão indica que não se trata de tráfego legítimo de aplicação interna, mas sim de **varredura ou fingerprinting** de serviços RPC.
- Apesar de não haver exploração visível, a exposição da porta UDP 1434 representa risco potencial de enumeração de serviços e futuras tentativas de exploração.
- Recomenda-se revisão de firewall, restrição de acesso externo e monitorização contínua de pacotes DCE/RPC.

Conclusão

- O trabalho desenvolvido ao longo desta **análise de tráfego de rede** e dos **exercícios práticos** associados demonstrou a importância crucial de avaliar cuidadosamente a segurança dos protocolos de comunicação e das configurações de sistemas centrais num ambiente de rede. Foi possível identificar problemas significativos relacionados com o uso de protocolos inseguros como **LDAP, POP3, FTP e Telnet**, que transmitem credenciais de autenticação e dados em texto claro, tornando-os altamente suscetíveis a ataques de intercepção (sniffing) e roubo de credenciais.
- Adicionalmente, o exercício prático com **RADIUS** evidenciou a vulnerabilidade de protocolos de autenticação mais antigos face a ataques de cracking de passwords, enquanto a exploração do **Active Directory** revelou como configurações incorretas podem ser mapeadas e levar à escalada de privilégios e vetores de ataque.
- Para mitigar esses riscos, foram apresentadas recomendações claras, focadas na migração para protocolos mais seguros que implementam encriptação, como **LDAPS/StartTLS, POP3S/IMAPS, SFTP/FTPS e SSH**. Foram também realçadas a importância da aplicação do **Princípio do Menor Privilégio**, especialmente no Active Directory, e a implementação de **Autenticação Multifator (MFA)** como camada adicional de segurança.
- Em suma, a combinação da análise passiva do tráfego com a exploração ativa e os exercícios práticos sublinha a necessidade de uma vigilância contínua sobre os protocolos e configurações de segurança em qualquer ambiente organizacional. A adoção de práticas seguras, auditorias regulares e a atualização de sistemas são essenciais para promover a proteção contra ataques e garantir a **confidencialidade, integridade e disponibilidade** dos dados.

Referências

- <https://github.com/davidprowe/BadBlood>
- <https://bloodhound.readthedocs.io/en/latest/>
- <https://book.hacktricks.wiki/en/index.html>
- <https://learn.microsoft.com/en-us/troubleshoot/windows-server/active-directory/active-directory-overview>
- <https://www.redhat.com/en/blog/linux-active-directory>
- <https://www.microsoft.com/en-us/evalcenter/download-windows-server-2019>
- <https://book.hacktricks.xyz/windows-hardening/active-directory-methodology>
- <https://www.redhat.com/pt-br/topics/security/what-is-ldap-authentication>
- <https://ldap.com/>
- <https://www.geeksforgeeks.org/computer-networks/what-is-transmission-control-protocol-tcp/>
- <https://hsclabs.com/pt-br/protocolo-pop3/>
- Powerpoints das aulas Teóricas, Teórico-Práticas, Prática-Laboratorial e de Apoio à Prática-Laboratorial

Análise Exercícios PLs

PL01 - Exercício 2

Describe the Radius protocol that you see (What it does, what purpose it serves and its security considerations).

- Ao contrário do protocolo PPP, o RADIUS garante que a palavra-passe não é enviada em texto claro. Utiliza um segredo partilhado/método de encriptação para proteger a palavra-passe durante a transmissão.
- Cada um dos Access-Request inclui um Id, e quando inspecionado de perto, podemos ver o Nome de Utilizador (Username) em texto claro, mas não a palavra-passe.

Describe the Challenge Authentication Principle?

- O Princípio de Autenticação Challenge-Response é um mecanismo de segurança usado para verificar a identidade de um utilizador ou dispositivo sem transmitir a palavra-passe real pela rede. Envolve um desafio (challenge) emitido pelo servidor e uma resposta (response) gerada pelo cliente com base nesse desafio.

Crack the credential using any password cracker such as JohnTheRipper or Hashcat.

- A palavra-passe foi crackada usando o John TheRipper com os seguintes passos e comandos:
 - Instalei a ferramenta: <https://github.com/openwall/john-packages/releases>.
 - Instalei uma wordlist: Neste caso, usei a wordlist rockyou.txt.
 - Fui ao Wireshark e abri o ficheiro Radius_Simple.cap.

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.0.0.1	10.0.0.100	RADIUS	181	Access-Request id=5
2	0.002803	10.0.0.100	10.0.0.1	RADIUS	151	Access-Challenge id=5
3	0.043768	10.0.0.1	10.0.0.100	RADIUS	216	Access-Request id=6
4	0.043882	10.0.0.100	10.0.0.1	RADIUS	139	Access-Accept id=6

- Para realizar este ataque, precisaremos da seguinte informação
 - O nome de utilizador (nickname) do utilizador: Encontrado no primeiro pacote Access-Request, neste caso "John.McGuirk".

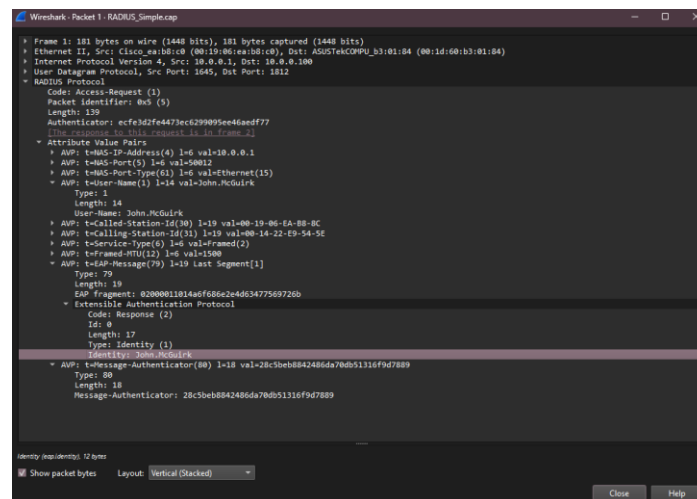


FIGURA 43 - USERNAME DA IDENTIDADE A SER ATACADA

- O valor do **challenge**: Encontrado no pacote **Access-Challenge**, neste caso "**266b0e9a58322f4d01ab25b35f879464**".
- O valor da **response**: Encontrado no segundo pacote **Access-Request**, neste caso "**c9f9769597e320843f5f2af7b8f1c9bd**".

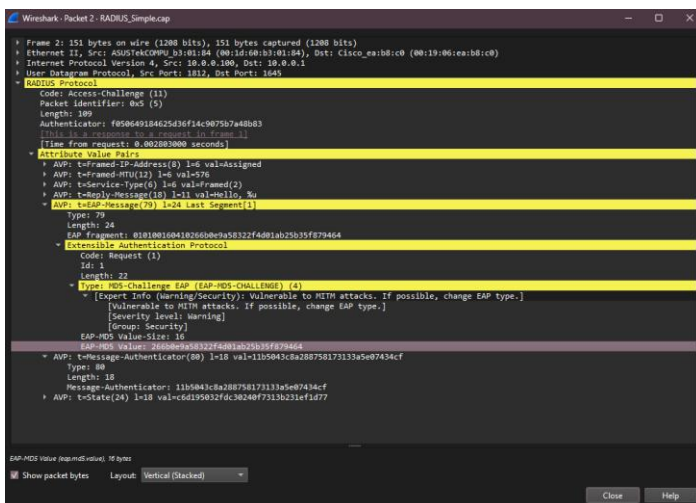


FIGURA 44 - VALOR DO CHALLENGE

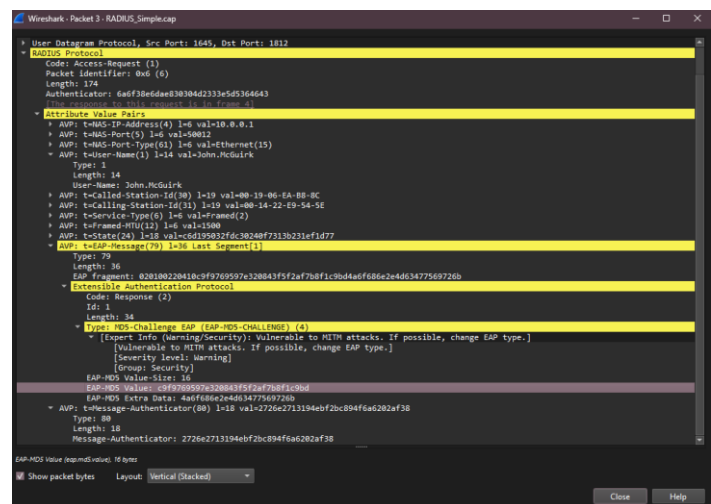


FIGURA 45 - VALOR DO REQUEST

- Com toda a informação, podemos começar a realizar o ataque:
 - Criei um ficheiro chamado "chap.txt" usando o seguinte comando:
 - John.McGuirk:\$chap\$01*266b0e9a58322f4d01ab25b35f879464*c9f9769597e320843f5f2af7b8f1c9bd | Out-File -NoNewline -Encoding ASCII .\chap.txt**
 - Corri o John The Ripper com o seguinte commando:
 - .\john.exe --format=chap --wordlist=.\rockyou.txt .\chap.txt**
 - O qual mostrou informação valiosa, confirmando que a password foi efetivamente crackada, no entanto, não mostrou a password.

```
PS D:\JTR\run> .\john.exe --format=chap --wordlist=.\rockyou.txt .\chap.txt
Using default input encoding: UTF-8
Loaded 1 password hash (chap, iSCSI CHAP authentication / EAP-MD5 [MD5 32/64])
Cracked 1 password hash (is in /cygdrive/d/JTR/run/john.pot), use "--show"
No password hashes left to crack (see FAQ)
```

FIGURA 46 - INFORMAÇÃO DE SUCESSO

- Portanto, após alguma pesquisa, corri este comando para mostrar a password:
 - .\john.exe --show chap.txt**
 - E, como esperado, mostrou o nome de utilizador juntamente com a password não encriptada: "John.McGuirk:S0cc3r"

```
PS D:\JTR\run> .\john.exe --show chap.txt
John.McGuirk:S0cc3r

1 password hash cracked, 0 left
```

FIGURA 47 - PASSWORD EM TEXTO

While it is comment on the resilience of the cipher.

cracking

- Enquanto fazia o ataque, tornou-se claro que a segurança da cifra depende da complexidade da palavra-passe. O challenge-response baseado em MD5 pode ser facilmente atacado por força bruta se a palavra-passe for fraca. O hardware e as ferramentas modernas tornam o challenge-response MD5 resiliente apenas para passwords fortes e únicas; caso contrário, é vulnerável a ataques offline rápidos.

PL03 - Exercício 3

Deploy BadBlood on your testing domain

- Abri então o PowerShell no Windows Server como administrador e corri estes comandos para instalar o BadBlood e correr:

```
PowerShell

[Net.ServicePointManager]::SecurityProtocol = [Net.SecurityProtocolType]::Tls12

$Url = "https://github.com/davidprowe/BadBlood/archive/refs/heads/master.zip"
$outputZip = "$env:TEMP\BadBlood.zip"
$extractPath = "$env:TEMP\BadBlood"

Invoke-WebRequest -Uri $Url -OutFile $outputZip

Expand-Archive -Path $outputZip -DestinationPath $extractPath -Force

cd "$extractPath\BadBlood-master"

Set-ExecutionPolicy -Scope Process -ExecutionPolicy Bypass

.\Invoke-BadBlood.ps1
```

FIGURA 48 - COMANDOS PARA INSTALAR BADBLOOD

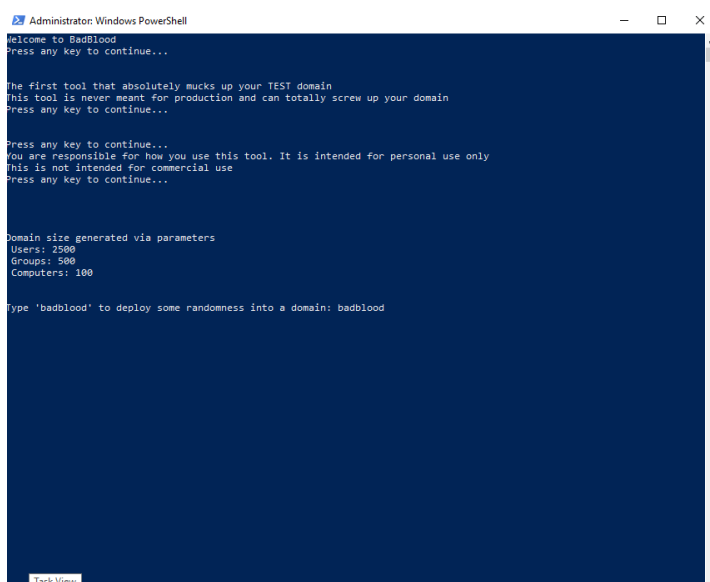


FIGURA 49 - RESULTADO DE CORRER OS COMANDOS

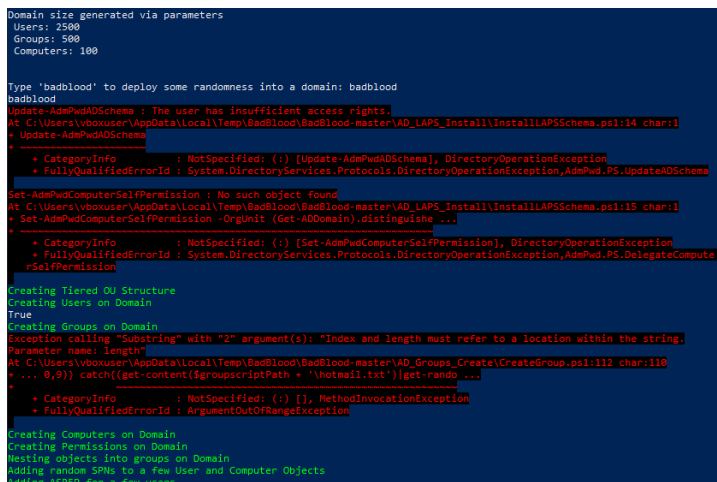


FIGURA 50 - RESULTADOS DE CORRER COMANDOS 2

Download and run Bloodhound

- No Windows Server, abri o powershell como administrador e corri estes comandos para instalar o BloodHound:

```
PS C:\Windows\system32> $url = "https://raw.githubusercontent.com/BloodHoundAD/BloodHound/master/Collectors/SharpHound.ps1"
PS C:\Windows\system32> Invoke-WebRequest -Uri $url -OutFile $outputFile
Invoke-WebRequest : Could not find a part of the path 'C:\Users\Administrator\Desktop\SharpHound.ps1'.
At line:1 char:1
+ Invoke-WebRequest -Uri $url -OutFile $outputFile
+ ~~~~~
+ CategoryInfo          : NotSpecified: (:) [Invoke-WebRequest], DirectoryNotFoundException
+ FullyQualifiedErrorId : System.IO.DirectoryNotFoundException,Microsoft.PowerShell.Commands.InvokeWebRequestCommand

PS C:\Windows\system32> $outputFile = "$env:USERPROFILE\Desktop\SharpHound.ps1"
PS C:\Windows\system32> Invoke-WebRequest -Uri $url -OutFile $outputFile
```

FIGURA 51 - COMANDOS PARA INSTALAR BLOODHOUND

- Mal acabei de instalar, o antivírus Windows Defender detetou o BloodHound como uma potencial ameaça.
- Para contornar isto, adicionei uma exceção no Windows Defender para a pasta onde o BloodHound está instalado.

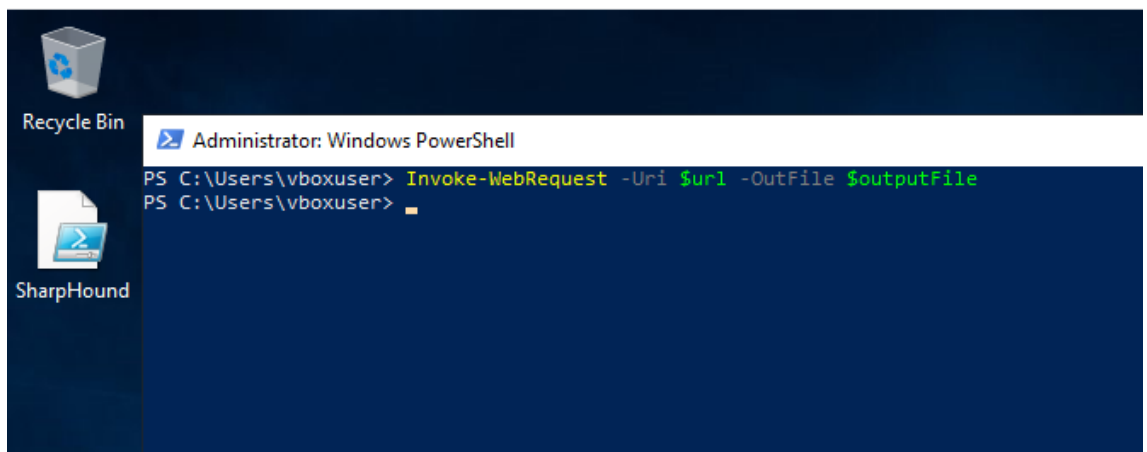


FIGURA 52 - COMANDOS PARA CONTORNAR WINDOWS DEFENDER

- Já com o ficheiro corretamente colocado no Desktop, desloquei-me para o Desktop e corri o BloodHound com o comando:

```
PS C:\Users\vboxuser> cd Desktop
PS C:\Users\vboxuser\Desktop> Import-Module .\SharpHound.ps1
PS C:\Users\vboxuser\Desktop> Invoke-BloodHound -CollectionMethod All -ZipfileName "bloodhound_results.zip"
2025-10-10T13:52:19.0307188+01:00|INFORMATION|This version of SharpHound is compatible with the 4.3.1 Release of BloodHound
2025-10-10T13:52:19.2078819+01:00|INFORMATION|Resolved Collection Methods: Group, LocalAdmin, GPOLocalGroup, Session, Logg
, ACL, Container, RDP, ObjectProps, DCOM, SPNTargets, PSRemote
2025-10-10T13:52:19.2078819+01:00|INFORMATION|Initializing SharpHound at 1:52 PM on 10/10/2025
2025-10-10T13:52:19.3775967+01:00|INFORMATION|[CommonLib LDAPUtils]Found usable Domain Controller for segsi.local : AD-Ser
cal
2025-10-10T13:52:19.5625067+01:00|INFORMATION|Flags: Group, LocalAdmin, GPOLocalGroup, Session, LoggedOn, Trusts, ACL, Con
ObjectProps, DCOM, SPNTargets, PSRemote
2025-10-10T13:52:20.0121127+01:00|INFORMATION|Beginning LDAP search for segsi.local
2025-10-10T13:53:03.3894328+01:00|INFORMATION|Status: 0 objects finished (+0 0)/s -- Using 96 MB RAM
2025-10-10T13:53:14.0843022+01:00|INFORMATION|Producer has finished, closing LDAP channel
2025-10-10T13:53:14.3777040+01:00|INFORMATION|LDAP channel closed, waiting for consumers
2025-10-10T13:53:14.9867637+01:00|INFORMATION|Consumers finished, closing output channel
2025-10-10T13:53:15.0432554+01:00|INFORMATION|Output channel closed, waiting for output task to complete
Closing writers
2025-10-10T13:53:15.1132306+01:00|INFORMATION|Status: 3404 objects finished (+3404 61.89091)/s -- Using 110 MB RAM
2025-10-10T13:53:15.1324643+01:00|INFORMATION|Enumeration finished in 00:00:55.0786616
2025-10-10T13:53:15.3150130+01:00|INFORMATION|Saving cache with stats: 3361 ID to type mappings.
3363 name to SID mappings.
0 machine sid mappings.
2 sid to domain mappings.
0 global catalog mappings.
2025-10-10T13:53:15.3150130+01:00|INFORMATION|SharpHound Enumeration Completed at 1:53 PM on 10/10/2025! Happy Graphing!
PS C:\Users\vboxuser\Desktop>
```

FIGURA 53 - COMANDOS PARA CORRER BLOODHOUND

•

 20251010144107_bloodhound_results	10/10/2025 2:41 PM	Compressed (zipp...	266 KB
 OGJINjRlZDktODc5MS00MGJkLTkxZGIhN...	10/10/2025 2:41 PM	BIN File	539 KB

FIGURA 54 - FICHEIRO DO RESULTADO DE CORRER O BLOODHOUND

- Com a ajuda de uma PEN passei o ficheiro para o meu computador local.

Nome	Data de modificação	Tipo	Tamanho
 20251010144107_bloodhound_results.zip	10/10/2025 14:41	WinRAR ZIP archive	266 KB

FIGURA 55 - FICHEIRO DO RESULTADO DE CORRER O BLOODHOUND FORA DA VM

Install Neo4J Desktop [5] and load your results into the Database using the BloodHound binaries

- Instalei o Neo4J Desktop no meu computador a partir do site oficial que está presente na aula PL03.
- Após a instalação, abri o Neo4J Desktop e criei uma base de dados chamada "SEGS-PL3".

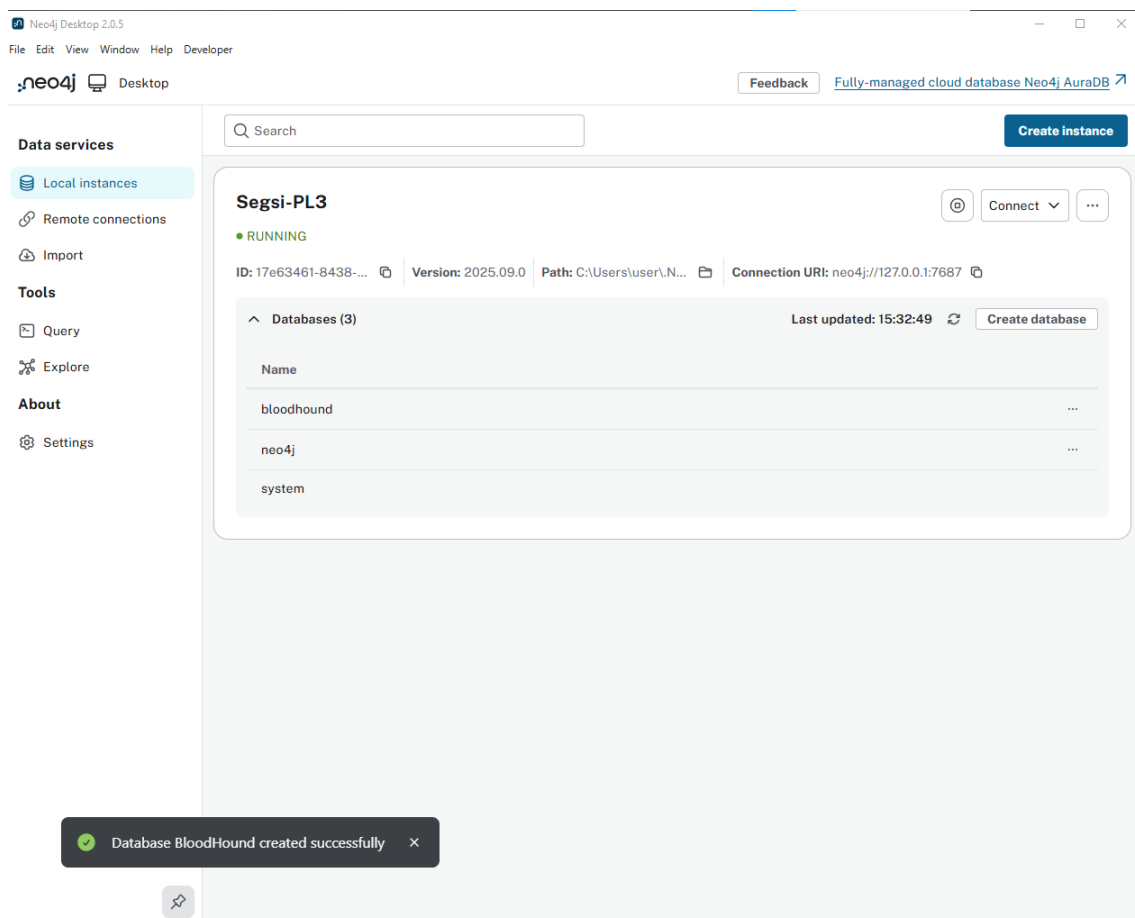


FIGURA 56 - BASE DE DADOS NO NEO4J

- No BloodHound, cliquei em "Connect" e preenchi os detalhes da conexão com a base de dados Neo4J:

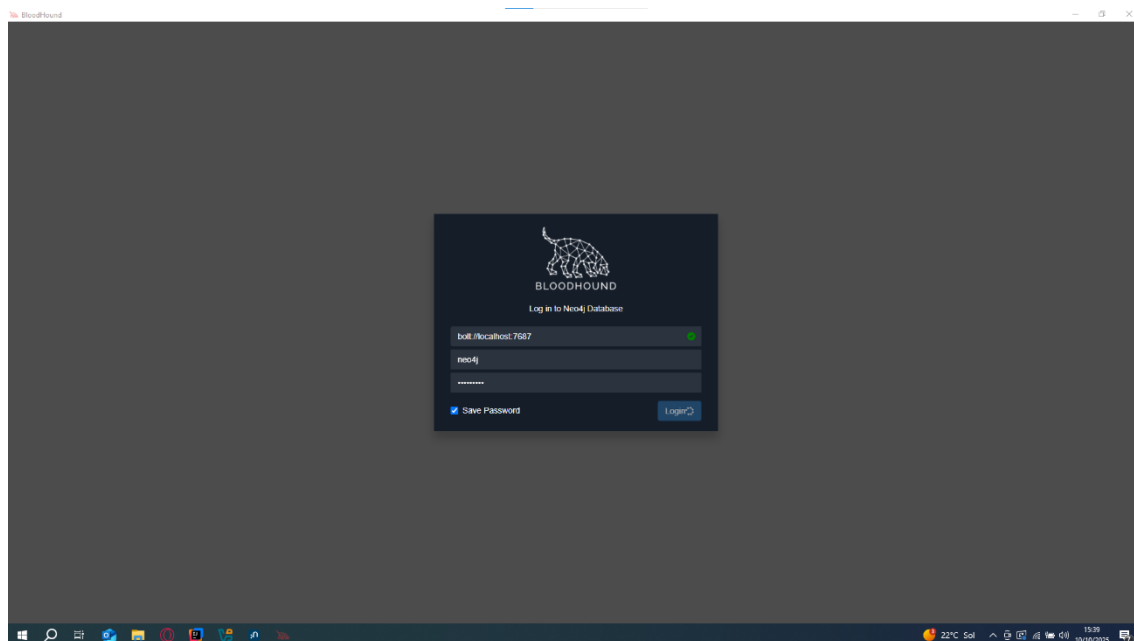


FIGURA 57 – CONEXÃO DO BLOODHOUND À BD

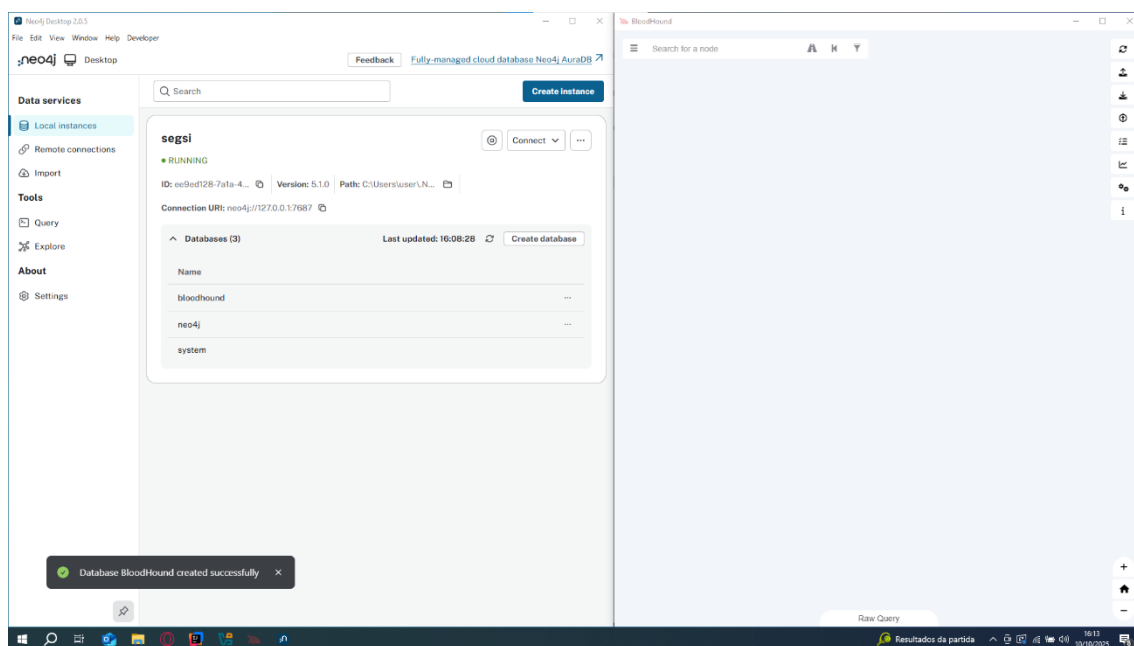


FIGURA 58 - CONEXÃO BEM SUCEDIDA

- Dentro do BloodHound, cliquei em "Upload Data" e selecionei o ficheiro JSON que exportei anteriormente com o BloodHound na VM (frutos da criação de users com o BadBlood). E esperei que o upload fosse concluído.

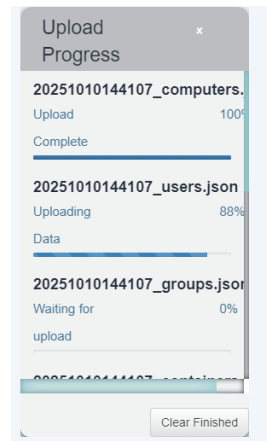


FIGURA 59 - UPLOAD DOS DADOS DO BLOODHOUND

Try to trace a potential attack vector and how could you exploit it using the Hacktricks Database

- Através do BloodHound já com os dados, desloquei-me até à aba de Analysis que inclui várias queries pré-definidas para identificar potenciais vetores de ataque. Selecionei a query "Find All Domain Admins" para identificar os alvos principais, administradores de domínio.
- Este foi o resultado:

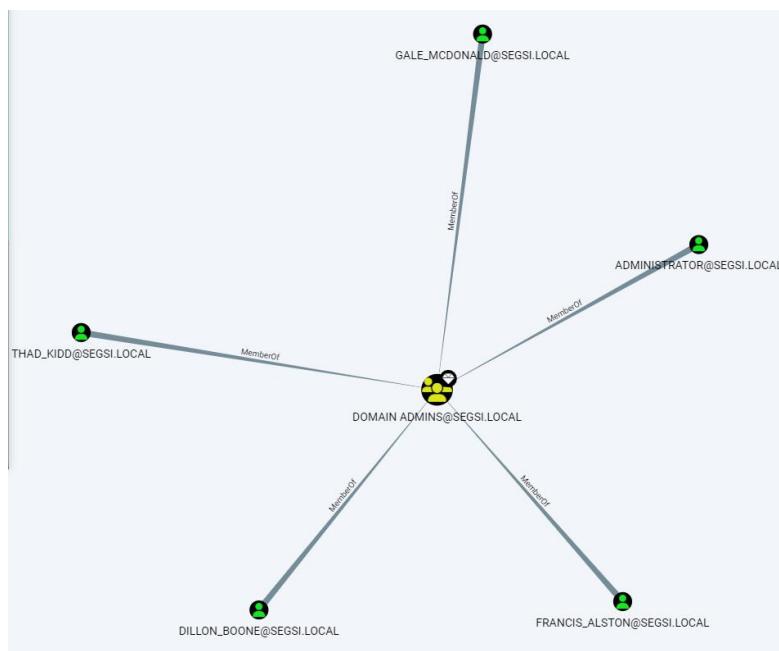


FIGURA 60 - DOMAIN ADMINS

- De forma a tentar encontrar um vetor de ataque, selecionei cada um dos nós e explorei as suas relações com outros objetos no domínio, como grupos, computadores e permissões delegadas.
- Vetor de Ataque: Foi identificado um vetor de ataque de potencial máximo. A conta GALE_MCDONALD@SEGS1.LOCAL é membro direto do grupo DOMAIN ADMINS.

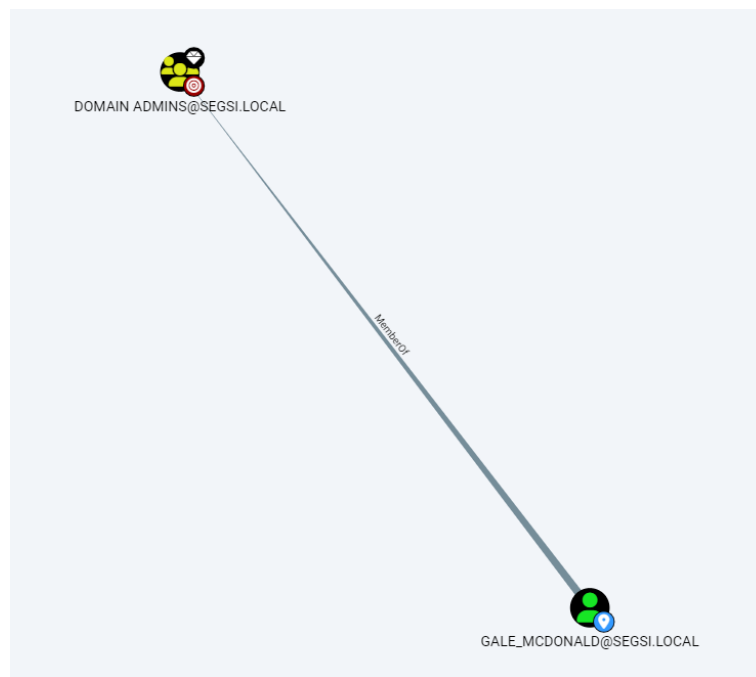


FIGURA 61 - VETOR DE ATAQUE

- Análise da Exploração (com base no Hacktricks): Conforme documentado na metodologia de análise do Active Directory do Hacktricks, o grupo Domain Admins detém o nível de privilégio mais elevado. A exploração deste vetor consiste no comprometimento das credenciais do utilizador GALE_MCDONALD. Uma vez obtido o acesso, um atacante teria imediatamente a capacidade de:
 - Aceder e administrar todos os Domain Controllers, podendo extrair a base de dados de passwords de todo o domínio.
 - Modificar a pertença de qualquer grupo, permitindo a criação de contas "backdoor" com privilégios persistentes.
 - Alterar Group Policies (GPOs) para desativar defesas de segurança em toda a rede ou para distribuir malware.
- O comprometimento de uma única conta neste grupo resulta no comprometimento total e imediato de todo o domínio segsi.local.